

ORTHRUS SECURITY REPORT

API Penetration Testing Report

Target:

<https://apihub-dev.hcuge.ch/v3/api-docs/APPOINTMENT-SERVICE>

Scan Date: 2026-06-06 13:22:57

Legal & Confidentiality Disclaimer

This report is STRICTLY CONFIDENTIAL and its distribution is subject to restriction. It is intended solely for authorized personnel. It is generated by an automated security testing tool (Orthrus). The tool assigns a theoretical Base CVSS score which may not reflect the environmental or temporal context of the vulnerability. The authors and the tool itself are not liable for any missed vulnerabilities, critical flaws that were not detected, or subsequent compromises of the tested systems. This tool is provided for authorized security testing only.

Methodology & Scoring Criteria

This report presents the findings of an automated Dynamic Application Security Testing (DAST) scan. The scan involved sending various malicious payloads and unexpected inputs to the target API to identify security vulnerabilities.

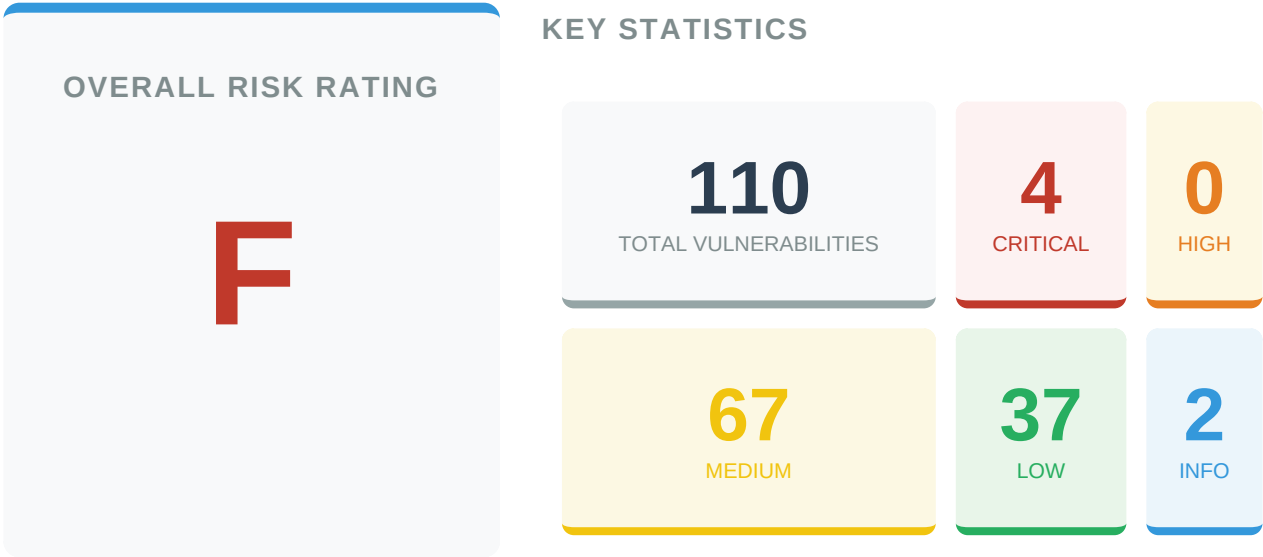
Methodology and Standards

Standard	Application
OWASP API Security Top 10	API-specific vulnerability classification & testing guidelines
OWASP Top 10 (2021)	Primary web vulnerability classification framework
CVSS v3.1	Common Vulnerability Scoring System for objective severity rating
CWE / CAPEC	Common Weakness Enumeration and Attack Pattern tracking
Automated DAST Assessment	Dynamic payload injection, fuzzing, and unauthenticated/authenticated state evaluation

Security Grade Definition

- A** Excellent security posture. No high or critical vulnerabilities detected.
- B** Good security posture. Minor vulnerabilities present, but no immediate critical threats.
- C** Fair security posture. Several medium vulnerabilities or a single high vulnerability require attention.
- D** Poor security posture. Multiple high vulnerabilities detected. Urgent remediation needed.
- F** Critical failure. One or more critical vulnerabilities detected, exposing the application to immediate and severe risks.

1. Global Summary



- CRITICAL:** Critical risk vulnerabilities indicate a severe and immediate threat to the application's security. They can typically be exploited without authentication and can lead to full system compromise or significant data breach. Immediate remediation is required.
- HIGH:** High risk vulnerabilities pose a significant threat. They often require some level of access or complex exploitation but can result in major data theft or system disruption. They should be addressed as a high priority.
- MEDIUM:** Medium risk vulnerabilities represent a moderate threat. They usually require specific preconditions or authorized access to be exploited. While not immediately critical, they should be fixed in the next scheduled update.
- LOW:** Low risk vulnerabilities have a minimal impact. They might expose non-sensitive information or require highly unlikely scenarios to exploit. They should be addressed when resources permit.
- INFO:** Informational findings do not represent a direct vulnerability but highlight security best practices that could be improved to strengthen the overall security posture.

2. Vulnerability Summary

Each finding is scored under both CVSS v3.1 (for parity with NVD, CISA KEV, and most vendor advisories) and CVSS v4.0 (current FIRST standard since November 2023). Severity bands are identical across both versions. Detailed finding entries include full v3.1 and v4.0 vectors. Scores reflect what the original engagement recorded; vectors are documented for reproducibility against the FIRST CVSS calculator.

Severity Distribution

Severity	Count	CVSS Range (v3.1 / v4.0)	Remediation Priority
CRITICAL	4	9.0 to 10.0	Immediate (before next release)
HIGH	0	7.0 to 8.9	Within 1 sprint cycle
MEDIUM	67	4.0 to 6.9	Within 2 sprint cycles
LOW	37	0.1 to 3.9	Next quarterly review
INFO	2	0.0	Best practice recommendation

3. Detailed Findings

Time-Based Blind SQL Injection

Severity: CRITICAL **Base CVSS Score:** 9.8 **CWE:** CWE_89
CAPEC Reference: CAPEC-66
OWASP: A05:2025 - Injection
Attack Vector: API Endpoint (Network)
Technical Impact: Unauthorized Access / Data Exposure

Endpoint: GET <https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/persons/{personId}/appointments>

Description

The endpoint took 5500ms to respond, indicating a potential Time-Based Blind SQL Injection in HTTP Header 'X-Forwarded-For'.

Evidence

Response was delayed by 5500ms when payload '1"; WAITFOR DELAY '0:0:5'--' was injected.

Request:

```
GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/persons/officia/appointments?
size=37&endDate=architecto&activityModelId=96&startDate=nihil
X-Forwarded-For: 1"; WAITFOR DELAY '0:0:5'--
```

Response:

```
Status: 400 BAD_REQUEST
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Content-Length: 372
Content-Security-Policy: default-src 'self' https;; font-src 'self' https: data;; img-src 'self'
https: data;; object-src 'none'; script-src https;; style-src 'self' https: 'unsafe-inline'
Content-Type: text/plain;charset=UTF-8
Date: Sat, 06 Jun 2026 13:23:24 GMT
Expires: 0
Pragma: no-cache
Referrer-Policy: no-referrer
Strict-Transport-Security: max-age=631138519
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
X-Content-Type-Options: nosniff
X-Correlation-Id: 86c3a84459d2f4b0972d0a1979818058
X-Download-Options: noopen
X-Frame-Options: DENY
X-Permitted-Cross-Domain-Policies: none
X-Ratelimit-Burst-Capacity: 150
X-Ratelimit-Remaining: 85
X-Ratelimit-Replenish-Rate: 100
X-Ratelimit-Requested-Tokens: 1
X-Xss-Protection: 0

Method parameter 'startDate': Failed to convert value of type 'java.lang.String' to required type
'java.time.ZonedDateTime'; Failed to convert from type [java.lang.String] to type [@org.
springframework.web.bind.annotation.RequestParam @org.springframework.format.annotation.
DateTimeFormat @io.swagger.v3.oas.annotations.Parameter java.time.ZonedDateTime] for value [nihil]
```

Remediation

Use parameterized queries or prepared statements.

Time-Based Blind OS Command Injection

Severity:

CRITICAL

Base CVSS Score:
9.8

CWE: CWE_78
CAPEC Reference: CAPEC-88
OWASP: A05:2025 - Injection
Attack Vector: API Endpoint (Network)
Technical Impact: Unauthorized Access / Data Exposure

Endpoint: PUT <https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/{id}>

Description

The endpoint took 5765ms to respond, indicating a potential Time-Based Blind Command Injection in HTTP Header 'X-Forwarded-For'.

Evidence

Response was delayed by 5765ms when payload ``sleep 5`` was injected.

Request:

```
PUT https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/37?
recurrenceUpdateOption=maiores&autoVisit=true
X-Forwarded-For: `sleep 5`
Content-Type: application/json

{"data": "voluptas"}
```

Response:

```
Status: 400 BAD_REQUEST
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Content-Length: 403
Content-Security-Policy: default-src 'self' https;; font-src 'self' https: data;; img-src 'self'
https: data;; object-src 'none'; script-src https;; style-src 'self' https: 'unsafe-inline'
Content-Type: text/plain;charset=UTF-8
Date: Sat, 06 Jun 2026 13:23:37 GMT
Expires: 0
Pragma: no-cache
Referrer-Policy: no-referrer
Strict-Transport-Security: max-age=631138519
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
X-Content-Type-Options: nosniff
X-Correlation-Id: 27f53b1ae171c0295e958fbd065db39a
X-Download-Options: noopen
X-Frame-Options: DENY
X-Permitted-Cross-Domain-Policies: none
X-Ratelimit-Burst-Capacity: 150
X-Ratelimit-Remaining: 60
X-Ratelimit-Replenish-Rate: 100
X-Ratelimit-Requested-Tokens: 1
X-Xss-Protection: 0

Method parameter 'recurrenceUpdateOption': Failed to convert value of type 'java.lang.String' to
required type 'ch.hcuge.service.appointment.enums.PeriodicityUpdateOption'; Failed to convert from
type [java.lang.String] to type [@org.springframework.web.bind.annotation.RequestParam @io.swagger.
v3.oas.annotations.Parameter ch.hcuge.service.appointment.enums.PeriodicityUpdateOption] for value
[maiores]
```

Remediation

Avoid invoking OS commands directly. Strictly sanitize and parameterize all input.

Time-Based Blind OS Command Injection

Severity:

CRITICAL

Base CVSS Score:

9.8

CWE:

CWE_78

CAPEC Reference:

CAPEC-88

OWASP:

A05:2025 - Injection

Attack Vector:

API Endpoint (Network)

Technical Impact:

Unauthorized Access / Data Exposure

Endpoint: PATCH <https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/{appointmentId}/patients/{patientId}/statu...> [TRUNCATED]

Description

The endpoint took 11800ms to respond, indicating a potential Time-Based Blind Command Injection in HTTP Header 'Referer'.

Evidence

Response was delayed by 11800ms when payload '; sleep 5' was injected.

Request:

```
PATCH https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/11/patients/98/status-and-encounter
Referer: ; sleep 5
Content-Type: application/json

{"data": "officiis"}
```

Response:

```
Status: 400 BAD_REQUEST
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Content-Security-Policy: default-src 'self' https;; font-src 'self' https: data;; img-src 'self' https: data;; object-src 'none'; script-src https;; style-src 'self' https: 'unsafe-inline'
Content-Type: application/json
Date: Sat, 06 Jun 2026 13:23:31 GMT
Expires: 0
Pragma: no-cache
Referrer-Policy: no-referrer
Strict-Transport-Security: max-age=631138519
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
X-Content-Type-Options: nosniff
X-Correlation-Id: a580a306e8137094b5a9ab7b26e43c56
X-Download-Options: noopen
X-Frame-Options: DENY
X-Permitted-Cross-Domain-Policies: none
X-Ratelimit-Burst-Capacity: 150
X-Ratelimit-Remaining: 62
X-Ratelimit-Replenish-Rate: 100
X-Ratelimit-Requested-Tokens: 1
X-Xss-Protection: 0
Transfer-Encoding: chunked

{"timestamp":"2026-06-06T13:23:31.399+00:00","status":400,"error":"Bad Request","path":"/APPOINTMENT-SERVICE/appointments/11/patients/98/status-and-encounter","trace-id":"a580a306e8137094b5a9ab7b26e43c56"}
```

Remediation

Avoid invoking OS commands directly. Strictly sanitize and parameterize all input.

Time-Based Blind OS Command Injection

Severity:

CRITICAL

Base CVSS Score:
9.8

CWE: CWE_78
CAPEC Reference: CAPEC-88
OWASP: A05:2025 - Injection
Attack Vector: API Endpoint (Network)
Technical Impact: Unauthorized Access / Data Exposure

Endpoint: PATCH `https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/{id}`

Description

The endpoint took 13808ms to respond, indicating a potential Time-Based Blind Command Injection in Query Parameter 'recurrenceUpdateOption'.

Evidence

Response was delayed by 13808ms when payload ';' sleep 5' was injected.

Request:

```
PATCH https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/7?recurrenceUpdateOption=; sleep
5&autoVisit=true
Content-Type: application/json

{"data": "iusto"}
```

Response:

```
Status: 403 FORBIDDEN
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Content-Length: 13
Content-Security-Policy: default-src 'self' https;; font-src 'self' https: data;; img-src 'self'
https: data;; object-src 'none'; script-src https;; style-src 'self' https: 'unsafe-inline'
Content-Type: text/plain;charset=UTF-8
Date: Sat, 06 Jun 2026 13:23:30 GMT
Expires: 0
Pragma: no-cache
Referrer-Policy: no-referrer
Strict-Transport-Security: max-age=631138519
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
X-Content-Type-Options: nosniff
X-Correlation-Id: c3c7eea98b48ae99267eb376f1db8648
X-Download-Options: noopen
X-Frame-Options: DENY
X-Permitted-Cross-Domain-Policies: none
X-Ratelimit-Burst-Capacity: 150
X-Ratelimit-Remaining: 44
X-Ratelimit-Replenish-Rate: 100
X-Ratelimit-Requested-Tokens: 1
X-Xss-Protection: 0

Access Denied
```

Remediation

Avoid invoking OS commands directly. Strictly sanitize and parameterize all input.

Reflected Cross-Site Scripting (XSS)

Severity:

MEDIUM

Base CVSS Score:

6.1

CWE:

CWE_79

CAPEC Reference:

CAPEC-63

OWASP:

A05:2025 - Injection

Attack Vector:

API Endpoint (Network)

Technical Impact:

Unauthorized Access / Data Exposure

Endpoint: PUT https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/{id}

Description

The endpoint reflects unencoded user input from Query Parameter 'recurrenceUpdateOption' into the response.

Evidence

Response contains the exact unencoded XSS payload. The response is not HTML, so the script won't execute directly in modern browsers, but could be dangerous if a frontend incorrectly inserts this JSON data into the DOM.

Request:

```
PUT https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/37?
recurrenceUpdateOption=<script>alert('XSS_VULNAPI_TEST')</script>&autoVisit=true
Content-Type: application/json

{"data": "voluptas"}
```

Response:

Status: 400 BAD_REQUEST

Cache-Control: no-cache, no-store, max-age=0, must-revalidate

Content-Length: 438

Content-Security-Policy: default-src 'self' https;; font-src 'self' https: data;; img-src 'self' https: data;; object-src 'none'; script-src https;; style-src 'self' https: 'unsafe-inline'

Content-Type: text/plain;charset=UTF-8

Date: Sat, 06 Jun 2026 13:23:02 GMT

Expires: 0

Pragma: no-cache

Referrer-Policy: no-referrer

Strict-Transport-Security: max-age=631138519

Vary: Origin

Vary: Access-Control-Request-Method

Vary: Access-Control-Request-Headers

X-Content-Type-Options: nosniff

X-Correlation-Id: b962e748db2afb5fed2b676165a5d122

X-Download-Options: noopen

X-Frame-Options: DENY

X-Permitted-Cross-Domain-Policies: none

X-Ratelimit-Burst-Capacity: 150

X-Ratelimit-Remaining: 122

X-Ratelimit-Replenish-Rate: 100

X-Ratelimit-Requested-Tokens: 1

X-Xss-Protection: 0

Method parameter 'recurrenceUpdateOption': Failed to convert value of type 'java.lang.String' to required type 'ch.hcuge.service.appointment.enums.PeriodicityUpdateOption'; Failed to convert from type [java.lang.String] to type [@org.springframework.web.bind.annotation.RequestParam @io.swagger.v3.oas.annotations.Parameter ch.hcuge.service.appointment.enums.PeriodicityUpdateOption] for value [<script>alert('XSS_VULNAPI_TEST')</script>]

Remediation

Contextually encode user input before reflecting it in responses. Ensure the Content-Type header is strictly set to application/json for APIs.

Weak Security Header: CSP

Severity:

MEDIUM

Base CVSS Score:

5.4

CWE: CWE_693

CAPEC Reference: CAPEC-63

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: PATCH https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/{id}

Description

The Content-Security-Policy header contains 'unsafe-inline' or 'unsafe-eval', which significantly reduces the protection against XSS attacks.

Evidence

CSP value contains unsafe directives: default-src 'self' https;; font-src 'self' https: data;; img-src 'self' https: data;; object-src 'none'; script-src https;; style-src 'self' https: 'unsafe-inline'

Request:

```
PATCH https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/7?
recurrenceUpdateOption=non&autoVisit=true
Content-Type: application/json

{"data": "iusto"}
```

Response:

```
Status: 400 BAD_REQUEST
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Content-Length: 399
Content-Security-Policy: default-src 'self' https;; font-src 'self' https: data;; img-src 'self'
https: data;; object-src 'none'; script-src https;; style-src 'self' https: 'unsafe-inline'
Content-Type: text/plain;charset=UTF-8
Date: Sat, 06 Jun 2026 13:23:02 GMT
Expires: 0
Pragma: no-cache
Referrer-Policy: no-referrer
Strict-Transport-Security: max-age=631138519
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
X-Content-Type-Options: nosniff
X-Correlation-Id: c76421054de5f487cdb9913ddecdbd977
X-Download-Options: noopen
X-Frame-Options: DENY
X-Permitted-Cross-Domain-Policies: none
X-Ratelimit-Burst-Capacity: 150
X-Ratelimit-Remaining: 105
X-Ratelimit-Replenish-Rate: 100
X-Ratelimit-Requested-Tokens: 1
X-Xss-Protection: 0

Method parameter 'recurrenceUpdateOption': Failed to convert value of type 'java.lang.String' to
required type 'ch.hcuge.service.appointment.enums.PeriodicityUpdateOption'; Failed to convert from
type [java.lang.String] to type [@org.springframework.web.bind.annotation.RequestParam @io.swagger.
v3.oas.annotations.Parameter ch.hcuge.service.appointment.enums.PeriodicityUpdateOption] for value
[non]
```

Remediation

Remove 'unsafe-inline' and 'unsafe-eval' from your CSP and use nonces or hashes instead.

Improper Input Validation (Missing Parameter Max Length (Unbounded))

Severity: MEDIUM **Base CVSS Score:** 5.3 **CWE:** CWE_20
CAPEC Reference: CAPEC-3
OWASP: A05:2025 - Injection
Attack Vector: API Endpoint (Network)
Technical Impact: Unauthorized Access / Data Exposure

Endpoint: PUT <https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/{id}>

Description

Parameter 'recurrenceUpdateOption' lacks a maxLength constraint. An abnormally large string (50 KB) was accepted, potential DoS.

Evidence

The server responded with 503 SERVICE_UNAVAILABLE instead of enforcing the schema constraint (should be 400).

Request:

```
PUT https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/37?recurrenceUpdateOption=AAAAAAAAAAAA
AAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAA...
[TRUNCATED]&autoVisit=true
Content-Type: application/json

{"data": "voluptas"}
```

Response:

```
Status: 503 SERVICE_UNAVAILABLE

Error: recvAddress(..) failed with error(-104): Connection reset by peer
```

Remediation

Ensure that all incoming data is strictly validated against the defined OpenAPI schema constraints (types, lengths, required fields) using a validation middleware before processing.

Reflected Cross-Site Scripting (XSS)

Severity: MEDIUM **Base CVSS Score:** 6.1 **CWE:** CWE_79
CAPEC Reference: CAPEC-63
OWASP: A05:2025 - Injection
Attack Vector: API Endpoint (Network)
Technical Impact: Unauthorized Access / Data Exposure

Endpoint: PATCH <https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/{id}>

Description

The endpoint reflects unencoded user input from Query Parameter 'recurrenceUpdateOption' into the response.

Evidence

Response contains the exact unencoded XSS payload. The response is not HTML, so the script won't execute directly in modern browsers, but could be dangerous if a frontend incorrectly inserts this JSON data into the DOM.

Request:

```
PATCH https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/7?
recurrenceUpdateOption=<script>alert('XSS_VULNAPI_TEST')</script>&autoVisit=true
Content-Type: application/json

{"data": "iusto"}
```

Response:

```
Status: 400 BAD_REQUEST
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Content-Length: 438
Content-Security-Policy: default-src 'self' https;; font-src 'self' https: data:; img-src 'self'
https: data:; object-src 'none'; script-src https;; style-src 'self' https: 'unsafe-inline'
Content-Type: text/plain;charset=UTF-8
Date: Sat, 06 Jun 2026 13:23:02 GMT
Expires: 0
Pragma: no-cache
Referrer-Policy: no-referrer
Strict-Transport-Security: max-age=631138519
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
X-Content-Type-Options: nosniff
X-Correlation-Id: f4a04ea59c33867b88861331de34488e
X-Download-Options: noopen
X-Frame-Options: DENY
X-Permitted-Cross-Domain-Policies: none
X-Ratelimit-Burst-Capacity: 150
X-Ratelimit-Remaining: 102
X-Ratelimit-Replenish-Rate: 100
X-Ratelimit-Requested-Tokens: 1
X-Xss-Protection: 0

Method parameter 'recurrenceUpdateOption': Failed to convert value of type 'java.lang.String' to
required type 'ch.hcuge.service.appointment.enums.PeriodicityUpdateOption'; Failed to convert from
type [java.lang.String] to type [@org.springframework.web.bind.annotation.RequestParam @io.swagger.
v3.oas.annotations.Parameter ch.hcuge.service.appointment.enums.PeriodicityUpdateOption] for value
[<script>alert('XSS_VULNAPI_TEST')</script>]
```

Remediation

Contextually encode user input before reflecting it in responses. Ensure the Content-Type header is strictly set to application/json for APIs.

Improper Input Validation (Missing Parameter Max Length (Unbounded))

Severity:

MEDIUM

Base CVSS Score:
5.3

CWE: CWE_20
CAPEC Reference: CAPEC-3
OWASP: A05:2025 - Injection
Attack Vector: API Endpoint (Network)
Technical Impact: Unauthorized Access / Data Exposure

Endpoint: PATCH https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/{id}

Description

Parameter 'recurrenceUpdateOption' lacks a maxLength constraint. An abnormally large string (50 KB) was accepted, potential DoS.

Evidence

The server responded with 503 SERVICE_UNAVAILABLE instead of enforcing the schema constraint (should be 400).

Request:

```
PATCH https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/7?recurrenceUpdateOption=AAAAAAAAAA
AAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAA...
[TRUNCATED]&autoVisit=true
Content-Type: application/json

{"data": "iusto"}
```

Response:

```
Status: 503 SERVICE_UNAVAILABLE

Error: recvAddress(..) failed with error(-104): Connection reset by peer
```

Remediation

Ensure that all incoming data is strictly validated against the defined OpenAPI schema constraints (types, lengths, required fields) using a validation middleware before processing.

Improper Input Validation (Missing Parameter Max Length (Unbounded))

Severity:

MEDIUM

Base CVSS Score:

5.3

CWE: CWE_20

CAPEC Reference: CAPEC-3

OWASP: A05:2025 - Injection

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: GET <https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/persons/{personId}/appointments>

Description

Parameter 'personId' lacks a maxLength constraint. An abnormally large string (50 KB) was accepted, potential DoS.

Evidence

The server responded with 503 SERVICE_UNAVAILABLE instead of enforcing the schema constraint (should be 400).

Request:

`GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/persons/AAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAA
AA
AAAA...[TRUNCATED]?size=37&endDate=architecto&activityModelId=96&startDate=nihil`

Response:

Status: 503 SERVICE_UNAVAILABLE

```
Error: recvAddress(..) failed with error(-104): Connection reset by peer
```

Remediation

Ensure that all incoming data is strictly validated against the defined OpenAPI schema constraints (types, lengths, required fields) using a validation middleware before processing.

Improper Input Validation (Missing Parameter Max Length (Unbounded))

Severity:

MEDIUM

Base CVSS Score:

5.3

CWE: CWE_20

CAPEC Reference: CAPEC-3

OWASP: A05:2025 - Injection

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: GET <https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/persons/{personId}/appointments>

Description

Parameter 'startDate' lacks a maxLength constraint. An abnormally large string (50 KB) was accepted, potential DoS.

Evidence

The server responded with 503 SERVICE_UNAVAILABLE instead of enforcing the schema constraint (should be 400).

Request:

```
GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/persons/officia/appointments?size=37&endDate=archit  
ecto&activityModelId=96&startDate=AAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAA  
AAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAA... [TRUNCATED]
```

Response:

Status: 503 SERVICE_UNAVAILABLE

```
Error: recvAddress(..) failed with error(-104): Connection reset by peer
```

Remediation

Ensure that all incoming data is strictly validated against the defined OpenAPI schema constraints (types, lengths, required fields) using a validation middleware before processing.

Improper Input Validation (Missing Parameter Max Length (Unbounded))

Severity:

MEDIUM

Base CVSS Score:
5.3

CWE: CWE_20
CAPEC Reference: CAPEC-3
OWASP: A05:2025 - Injection
Attack Vector: API Endpoint (Network)
Technical Impact: Unauthorized Access / Data Exposure

Endpoint: GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/persons/{personId}/appointments

Description

Parameter 'endDate' lacks a maxLength constraint. An abnormally large string (50 KB) was accepted, potential DoS.

Evidence

The server responded with 503 SERVICE_UNAVAILABLE instead of enforcing the schema constraint (should be 400).

Request:

```
GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/persons/officia/appointments?size=37&endDate=AAAAAA
AAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAA...
[TRUNCATED]&activityModelId=96&startDate=nihil
```

Response:

```
Status: 503 SERVICE_UNAVAILABLE

Error: recvAddress(..) failed with error(-104): Connection reset by peer
```

Remediation

Ensure that all incoming data is strictly validated against the defined OpenAPI schema constraints (types, lengths, required fields) using a validation middleware before processing.

Weak Security Header: CSP

Severity:

MEDIUM

Base CVSS Score:
5.4

CWE: CWE_693
CAPEC Reference: CAPEC-63
OWASP: A02:2025 - Security Misconfiguration
Attack Vector: API Endpoint (Network)
Technical Impact: Unauthorized Access / Data Exposure

Endpoint: PUT https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/{id}

Description

The Content-Security-Policy header contains 'unsafe-inline' or 'unsafe-eval', which significantly reduces the protection against XSS attacks.

Evidence

CSP value contains unsafe directives: default-src 'self' https;; font-src 'self' https: data;; img-src 'self' https: data;; object-src 'none'; script-src https;; style-src 'self' https: 'unsafe-inline'

Request:

```
PUT https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/37?
recurrenceUpdateOption=maiores&autoVisit=true
Content-Type: application/json

{"data": "voluptas"}
```

Response:

```
Status: 400 BAD_REQUEST
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Content-Length: 403
Content-Security-Policy: default-src 'self' https;; font-src 'self' https: data;; img-src 'self'
https: data;; object-src 'none'; script-src https;; style-src 'self' https: 'unsafe-inline'
Content-Type: text/plain;charset=UTF-8
Date: Sat, 06 Jun 2026 13:23:02 GMT
Expires: 0
Pragma: no-cache
Referrer-Policy: no-referrer
Strict-Transport-Security: max-age=631138519
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
X-Content-Type-Options: nosniff
X-Correlation-Id: e6209b27be8b2eeacd49764e3b585aae
X-Download-Options: noopen
X-Frame-Options: DENY
X-Permitted-Cross-Domain-Policies: none
X-Ratelimit-Burst-Capacity: 150
X-Ratelimit-Remaining: 99
X-Ratelimit-Replenish-Rate: 100
X-Ratelimit-Requested-Tokens: 1
X-Xss-Protection: 0

Method parameter 'recurrenceUpdateOption': Failed to convert value of type 'java.lang.String' to
required type 'ch.hcuge.service.appointment.enums.PeriodicityUpdateOption'; Failed to convert from
type [java.lang.String] to type [@org.springframework.web.bind.annotation.RequestParam @io.swagger.
v3.oas.annotations.Parameter ch.hcuge.service.appointment.enums.PeriodicityUpdateOption] for value
[maiores]
```

Remediation

Remove 'unsafe-inline' and 'unsafe-eval' from your CSP and use nonces or hashes instead.

Verbose Error Information Leak

Severity:

MEDIUM

Base CVSS Score:

5.3

CWE:

CWE_209

CAPEC Reference:

CAPEC-54

OWASP:

A02:2025 - Security Misconfiguration

Attack Vector:

API Endpoint (Network)

Technical Impact:

Unauthorized Access / Data Exposure

Endpoint:

GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/persons/{personId}/appointments

Description

The endpoint returns detailed error messages or stack traces when processing invalid input.

Evidence

Response contains stack traces or framework-specific internal errors after sending malformed or type-mismatched query parameters.

Request:

```
GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/persons/officia/appointments?size=not_a_number_'[]{}&endDate=architecto%00%ff'"&activityModelId=not_a_number_'[]{}&startDate=nihil%00%ff'"
```

Response:

```
Status: 400 BAD_REQUEST
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Content-Length: 153
Content-Security-Policy: default-src 'self' https;; font-src 'self' https: data:; img-src 'self' https: data:; object-src 'none'; script-src https;; style-src 'self' https: 'unsafe-inline'
Content-Type: text/plain;charset=UTF-8
Date: Sat, 06 Jun 2026 13:23:02 GMT
Expires: 0
Pragma: no-cache
Referrer-Policy: no-referrer
Strict-Transport-Security: max-age=631138519
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
X-Content-Type-Options: nosniff
X-Correlation-Id: ee326597ce8a74b514ac0b878be617fc
X-Download-Options: noopen
X-Frame-Options: DENY
X-Permitted-Cross-Domain-Policies: none
X-Ratelimit-Burst-Capacity: 150
X-Ratelimit-Remaining: 34
X-Ratelimit-Replenish-Rate: 100
X-Ratelimit-Requested-Tokens: 1
X-Xss-Protection: 0

Method parameter 'size': Failed to convert value of type 'java.lang.String' to required type 'java.lang.Integer'; For input string: "not_a_number_'[]{}"
```

Remediation

Configure your framework to return generic error messages to the client. Log detailed errors internally only.

Weak Security Header: CSP

Severity:

MEDIUM

Base CVSS Score:

5.4

CWE:

CWE_693

CAPEC Reference:

CAPEC-63

OWASP:

A02:2025 - Security Misconfiguration

Attack Vector:

API Endpoint (Network)

Technical Impact:

Unauthorized Access / Data Exposure

Endpoint:

GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/persons/{personId}/appointments

Description

The Content-Security-Policy header contains 'unsafe-inline' or 'unsafe-eval', which significantly reduces the protection against XSS attacks.

Evidence

CSP value contains unsafe directives: default-src 'self' https;; font-src 'self' https: data;; img-src 'self' https: data;; object-src 'none'; script-src https;; style-src 'self' https: 'unsafe-inline'

Request:

```
GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/persons/officia/appointments?
size=37&endDate=architecto&activityModelId=96&startDate=nihil
```

Response:

```
Status: 400 BAD_REQUEST
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Content-Length: 372
Content-Security-Policy: default-src 'self' https;; font-src 'self' https: data;; img-src 'self'
https: data;; object-src 'none'; script-src https;; style-src 'self' https: 'unsafe-inline'
Content-Type: text/plain;charset=UTF-8
Date: Sat, 06 Jun 2026 13:23:02 GMT
Expires: 0
Pragma: no-cache
Referrer-Policy: no-referrer
Strict-Transport-Security: max-age=631138519
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
X-Content-Type-Options: nosniff
X-Correlation-Id: f037589b3e6e108cd799b33dd8acde2b
X-Download-Options: noopen
X-Frame-Options: DENY
X-Permitted-Cross-Domain-Policies: none
X-Ratelimit-Burst-Capacity: 150
X-Ratelimit-Remaining: 31
X-Ratelimit-Replenish-Rate: 100
X-Ratelimit-Requested-Tokens: 1
X-Xss-Protection: 0

Method parameter 'startDate': Failed to convert value of type 'java.lang.String' to required type
'java.time.ZonedDateTime'; Failed to convert from type [java.lang.String] to type [org.
springframework.web.bind.annotation.RequestParam @org.springframework.format.annotation.
DateTimeFormat @io.swagger.v3.oas.annotations.Parameter java.time.ZonedDateTime] for value [nihil]
```

Remediation

Remove 'unsafe-inline' and 'unsafe-eval' from your CSP and use nonces or hashes instead.

Weak Security Header: CSP

Severity:

MEDIUM

Base CVSS Score:
5.4

CWE: CWE_693
CAPEC Reference: CAPEC-63
OWASP: A02:2025 - Security Misconfiguration
Attack Vector: API Endpoint (Network)
Technical Impact: Unauthorized Access / Data Exposure

Endpoint: DELETE `https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/{id}`

Description

The Content-Security-Policy header contains 'unsafe-inline' or 'unsafe-eval', which significantly reduces the protection against XSS attacks.

Evidence

CSP value contains unsafe directives: default-src 'self' https;; font-src 'self' https: data;; img-src 'self' https: data;; object-src 'none'; script-src https;; style-src 'self' https: 'unsafe-inline'

Request:

```
DELETE https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/43?recurrenceDeleteOption=illo
Content-Type: application/json
```

```
{"data": "in"}
```

Response:

```
Status: 400 BAD_REQUEST
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Content-Length: 400
Content-Security-Policy: default-src 'self' https;; font-src 'self' https: data;; img-src 'self' https: data;; object-src 'none'; script-src https;; style-src 'self' https: 'unsafe-inline'
Content-Type: text/plain;charset=UTF-8
Date: Sat, 06 Jun 2026 13:23:02 GMT
Expires: 0
Pragma: no-cache
Referrer-Policy: no-referrer
Strict-Transport-Security: max-age=631138519
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
X-Content-Type-Options: nosniff
X-Correlation-Id: 9f8a5d5cefed4b19d6372966d1b9094b
X-Download-Options: noopen
X-Frame-Options: DENY
X-Permitted-Cross-Domain-Policies: none
X-Ratelimit-Burst-Capacity: 150
X-Ratelimit-Remaining: 71
X-Ratelimit-Replenish-Rate: 100
X-Ratelimit-Requested-Tokens: 1
X-Xss-Protection: 0

Method parameter 'recurrenceDeleteOption': Failed to convert value of type 'java.lang.String' to required type 'ch.hcuge.service.appointment.enums.PeriodicityUpdateOption'; Failed to convert from type [java.lang.String] to type [@org.springframework.web.bind.annotation.RequestParam @io.swagger.v3.oas.annotations.Parameter ch.hcuge.service.appointment.enums.PeriodicityUpdateOption] for value [illo]
```

Remediation

Remove 'unsafe-inline' and 'unsafe-eval' from your CSP and use nonces or hashes instead.

Weak Security Header: CSP

Severity:

MEDIUM

Base CVSS Score: 5.4

CWE: CWE_693
CAPEC Reference: CAPEC-63
OWASP: A02:2025 - Security Misconfiguration
Attack Vector: API Endpoint (Network)
Technical Impact: Unauthorized Access / Data Exposure

Endpoint: GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments

Description

The Content-Security-Policy header contains 'unsafe-inline' or 'unsafe-eval', which significantly reduces the protection against XSS attacks.

Evidence

CSP value contains unsafe directives: default-src 'self' https;; font-src 'self' https: data;; img-src 'self' https: data;; object-src 'none'; script-src https;; style-src 'self' https: 'unsafe-inline'

Request:

```
GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments?appointmentType=deleniti&participantActorId=dignissimos&trajectoryAdmissionState=eos&participantType=magni&start=quam&removeCancelled=true&singlePatient=true&patientAdmissionState=error&size=72&excludePending=true&end=quasi&page=69&excludeWithoutPatient=true&medicalServiceId=28&status=quis&order=ut
```

Response:

```
Status: 400 BAD_REQUEST
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Content-Length: 378
Content-Security-Policy: default-src 'self' https;; font-src 'self' https: data;; img-src 'self' https: data;; object-src 'none'; script-src https;; style-src 'self' https: 'unsafe-inline'
Content-Type: text/plain;charset=UTF-8
Date: Sat, 06 Jun 2026 13:23:02 GMT
Expires: 0
Pragma: no-cache
Referrer-Policy: no-referrer
Strict-Transport-Security: max-age=631138519
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
X-Content-Type-Options: nosniff
X-Correlation-Id: f6ff2bef9234750d1bd866866bc183ff
X-Download-Options: noopen
X-Frame-Options: DENY
X-Permitted-Cross-Domain-Policies: none
X-Ratelimit-Burst-Capacity: 150
X-Ratelimit-Remaining: 17
X-Ratelimit-Replenish-Rate: 100
X-Ratelimit-Requested-Tokens: 1
X-Xss-Protection: 0
```

```
Method parameter 'participantType': Failed to convert value of type 'java.lang.String' to required type 'ch.hcuge.service.appointment.enums.ParticipantType'; Failed to convert from type [java.lang.String] to type [@org.springframework.web.bind.annotation.RequestParam @io.swagger.v3.oas.annotations.Parameter ch.hcuge.service.appointment.enums.ParticipantType] for value [magni]
```

Remediation

Remove 'unsafe-inline' and 'unsafe-eval' from your CSP and use nonces or hashes instead.

Weak Security Header: CSP

Severity:

MEDIUM

Base CVSS Score:

5.4

CWE:

CWE_693

CAPEC Reference:

CAPEC-63

OWASP:

A02:2025 - Security Misconfiguration

Attack Vector:

API Endpoint (Network)

Technical Impact:

Unauthorized Access / Data Exposure

Endpoint: GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/patients/{id}/appointments

Description

The Content-Security-Policy header contains 'unsafe-inline' or 'unsafe-eval', which significantly reduces the protection against XSS attacks.

Evidence

CSP value contains unsafe directives: default-src 'self' https;; font-src 'self' https: data;; img-src 'self' https: data;; object-src 'none'; script-src https;; style-src 'self' https: 'unsafe-inline'

Request:

```
GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/patients/59/appointments?
size=44&endDate=dolorum&startDate=amet
```

Response:

```
Status: 400 BAD_REQUEST
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Content-Length: 371
Content-Security-Policy: default-src 'self' https;; font-src 'self' https: data;; img-src 'self'
https: data;; object-src 'none'; script-src https;; style-src 'self' https: 'unsafe-inline'
Content-Type: text/plain;charset=UTF-8
Date: Sat, 06 Jun 2026 13:23:02 GMT
Expires: 0
Pragma: no-cache
Referrer-Policy: no-referrer
Strict-Transport-Security: max-age=631138519
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
X-Content-Type-Options: nosniff
X-Correlation-Id: ef453d4c5a251136e7590654589970c4
X-Download-Options: noopen
X-Frame-Options: DENY
X-Permitted-Cross-Domain-Policies: none
X-Ratelimit-Burst-Capacity: 150
X-Ratelimit-Remaining: 27
X-Ratelimit-Replenish-Rate: 100
X-Ratelimit-Requested-Tokens: 1
X-Xss-Protection: 0

Method parameter 'startDate': Failed to convert value of type 'java.lang.String' to required type
'java.time.ZonedDateTime'; Failed to convert from type [java.lang.String] to type [@io.swagger.v3.
oas.annotations.Parameter @org.springframework.web.bind.annotation.RequestParam @org.
springframework.format.annotation.DateTimeFormat java.time.ZonedDateTime] for value [amet]
```

Remediation

Remove 'unsafe-inline' and 'unsafe-eval' from your CSP and use nonces or hashes instead.

Verbose Error Information Leak

Severity:

MEDIUM

Base CVSS Score:

5.3

CWE:

CWE_209

CAPEC Reference:

CAPEC-54

OWASP:

A02:2025 - Security Misconfiguration

Attack Vector:

API Endpoint (Network)

Technical Impact:

Unauthorized Access / Data Exposure

Endpoint: PATCH <https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/{id}>

Description

The endpoint returns detailed error messages or stack traces when processing invalid input.

Evidence

Response contains stack traces or framework-specific internal errors after sending malformed JSON in the request body.

Request:

```
PATCH https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/7?
recurrenceUpdateOption=non&autoVisit=true
Content-Type: application/json

{"broken": "json", "unterminated_array": [
```

Response:

```
Status: 400 BAD_REQUEST
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Content-Length: 399
Content-Security-Policy: default-src 'self' https;; font-src 'self' https: data;; img-src 'self'
https: data;; object-src 'none'; script-src https;; style-src 'self' https: 'unsafe-inline'
Content-Type: text/plain;charset=UTF-8
Date: Sat, 06 Jun 2026 13:23:02 GMT
Expires: 0
Pragma: no-cache
Referrer-Policy: no-referrer
Strict-Transport-Security: max-age=631138519
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
X-Content-Type-Options: nosniff
X-Correlation-Id: f7acbf4189cf0319023d60b09bd22a7c
X-Download-Options: noopen
X-Frame-Options: DENY
X-Permitted-Cross-Domain-Policies: none
X-Ratelimit-Burst-Capacity: 150
X-Ratelimit-Remaining: 103
X-Ratelimit-Replenish-Rate: 100
X-Ratelimit-Requested-Tokens: 1
X-Xss-Protection: 0

Method parameter 'recurrenceUpdateOption': Failed to convert value of type 'java.lang.String' to
required type 'ch.hcuge.service.appointment.enums.PeriodicityUpdateOption'; Failed to convert from
type [java.lang.String] to type [@org.springframework.web.bind.annotation.RequestParam @io.swagger.
v3.oas.annotations.Parameter ch.hcuge.service.appointment.enums.PeriodicityUpdateOption] for value
[non]
```

Remediation

Configure your framework to return generic error messages to the client. Log detailed errors internally only.

Verbose Error Information Leak

Severity:

MEDIUM

Base CVSS Score:

5.3

CWE:

CWE_209

CAPEC Reference:

CAPEC-54

OWASP:

A02:2025 - Security Misconfiguration

Attack Vector:

API Endpoint (Network)

Technical Impact:

Unauthorized Access / Data Exposure

Endpoint:

PATCH https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/{id}

Description

The endpoint returns detailed error messages or stack traces when processing invalid input.

Evidence

Response contains stack traces or framework-specific internal errors after sending malformed or type-mismatched query parameters.

Request:

```
PATCH https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/7?recurrenceUpdateOption=non%00%ff'"&autoVisit=true%00%ff'"
Content-Type: application/json

{"data": "iusto"}
```

Response:

```
Status: 400 BAD_REQUEST
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Content-Length: 407
Content-Security-Policy: default-src 'self' https;; font-src 'self' https: data;; img-src 'self' https: data;; object-src 'none'; script-src https;; style-src 'self' https: 'unsafe-inline'
Content-Type: text/plain;charset=UTF-8
Date: Sat, 06 Jun 2026 13:23:02 GMT
Expires: 0
Pragma: no-cache
Referrer-Policy: no-referrer
Strict-Transport-Security: max-age=631138519
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
X-Content-Type-Options: nosniff
X-Correlation-Id: 620198b2b75450b114e53e0d1d57523b
X-Download-Options: noopen
X-Frame-Options: DENY
X-Permitted-Cross-Domain-Policies: none
X-Ratelimit-Burst-Capacity: 150
X-Ratelimit-Remaining: 54
X-Ratelimit-Replenish-Rate: 100
X-Ratelimit-Requested-Tokens: 1
X-Xss-Protection: 0

Method parameter 'recurrenceUpdateOption': Failed to convert value of type 'java.lang.String' to required type 'ch.hcuge.service.appointment.enums.PeriodicityUpdateOption'; Failed to convert from type [java.lang.String] to type [@org.springframework.web.bind.annotation.RequestParam @io.swagger.v3.oas.annotations.Parameter ch.hcuge.service.appointment.enums.PeriodicityUpdateOption] for value [non%00%ff']
```

Remediation

Configure your framework to return generic error messages to the client. Log detailed errors internally only.

Verbose Error Information Leak

Severity:

MEDIUM

Base CVSS Score:

5.3

CWE:

CWE_209

CAPEC Reference:

CAPEC-54

OWASP:

A02:2025 - Security Misconfiguration

Attack Vector:

API Endpoint (Network)

Technical Impact:

Unauthorized Access / Data Exposure

Endpoint:

PUT https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/{id}

Description

The endpoint returns detailed error messages or stack traces when processing invalid input.

Evidence

Response contains stack traces or framework-specific internal errors after sending malformed JSON in the request body.

Request:

```
PUT https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/37?
recurrenceUpdateOption=maiores&autoVisit=true
Content-Type: application/json

{"broken": "json", "unterminated_array": [
```

Response:

```
Status: 400 BAD_REQUEST
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Content-Length: 403
Content-Security-Policy: default-src 'self' https;; font-src 'self' https: data;; img-src 'self'
https: data;; object-src 'none'; script-src https;; style-src 'self' https: 'unsafe-inline'
Content-Type: text/plain;charset=UTF-8
Date: Sat, 06 Jun 2026 13:23:02 GMT
Expires: 0
Pragma: no-cache
Referrer-Policy: no-referrer
Strict-Transport-Security: max-age=631138519
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
X-Content-Type-Options: nosniff
X-Correlation-Id: 67453ee356ece934cde6ef99566df43f
X-Download-Options: noopen
X-Frame-Options: DENY
X-Permitted-Cross-Domain-Policies: none
X-Ratelimit-Burst-Capacity: 150
X-Ratelimit-Remaining: 106
X-Ratelimit-Replenish-Rate: 100
X-Ratelimit-Requested-Tokens: 1
X-Xss-Protection: 0

Method parameter 'recurrenceUpdateOption': Failed to convert value of type 'java.lang.String' to
required type 'ch.hcuge.service.appointment.enums.PeriodicityUpdateOption'; Failed to convert from
type [java.lang.String] to type [@org.springframework.web.bind.annotation.RequestParam @io.swagger.
v3.oas.annotations.Parameter ch.hcuge.service.appointment.enums.PeriodicityUpdateOption] for value
[maiores]
```

Remediation

Configure your framework to return generic error messages to the client. Log detailed errors internally only.

Verbose Error Information Leak

Severity:

MEDIUM

Base CVSS Score:

5.3

CWE:

CWE_209

CAPEC Reference:

CAPEC-54

OWASP:

A02:2025 - Security Misconfiguration

Attack Vector:

API Endpoint (Network)

Technical Impact:

Unauthorized Access / Data Exposure

Endpoint:

PUT https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/{id}

Description

The endpoint returns detailed error messages or stack traces when processing invalid input.

Evidence

Response contains stack traces or framework-specific internal errors after sending malformed or type-mismatched query parameters.

Request:

```
PUT https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/37?recurrenceUpdateOption=maiores%00%ff'"&autoVisit=true%00%ff'"
Content-Type: application/json

{"data": "voluptas"}
```

Response:

```
Status: 400 BAD_REQUEST
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Content-Length: 411
Content-Security-Policy: default-src 'self' https;; font-src 'self' https: data;; img-src 'self' https: data;; object-src 'none'; script-src https;; style-src 'self' https: 'unsafe-inline'
Content-Type: text/plain;charset=UTF-8
Date: Sat, 06 Jun 2026 13:23:02 GMT
Expires: 0
Pragma: no-cache
Referrer-Policy: no-referrer
Strict-Transport-Security: max-age=631138519
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
X-Content-Type-Options: nosniff
X-Correlation-Id: 26990b00119e2d39177072d8b15147ad
X-Download-Options: noopen
X-Frame-Options: DENY
X-Permitted-Cross-Domain-Policies: none
X-Ratelimit-Burst-Capacity: 150
X-Ratelimit-Remaining: 13
X-Ratelimit-Replenish-Rate: 100
X-Ratelimit-Requested-Tokens: 1
X-Xss-Protection: 0

Method parameter 'recurrenceUpdateOption': Failed to convert value of type 'java.lang.String' to required type 'ch.hcuge.service.appointment.enums.PeriodicityUpdateOption'; Failed to convert from type [java.lang.String] to type [@org.springframework.web.bind.annotation.RequestParam @io.swagger.v3.oas.annotations.Parameter ch.hcuge.service.appointment.enums.PeriodicityUpdateOption] for value [maiores%00%ff']
```

Remediation

Configure your framework to return generic error messages to the client. Log detailed errors internally only.

Improper Input Validation (Missing Parameter Max Length (Unbounded))

Severity:

MEDIUM

Base CVSS Score:
5.3

CWE: CWE_20
CAPEC Reference: CAPEC-3
OWASP: A05:2025 - Injection
Attack Vector: API Endpoint (Network)
Technical Impact: Unauthorized Access / Data Exposure

Endpoint: DELETE https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/{id}

Description

Parameter 'recurrenceDeleteOption' lacks a maxLength constraint. An abnormally large string (50 KB) was accepted, potential DoS.

Evidence

The server responded with 503 SERVICE_UNAVAILABLE instead of enforcing the schema constraint (should be 400).

Request:

```
DELETE https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/43?recurrenceDeleteOption=AAAAAAAAA
AAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAA...
[TRUNCATED]
Content-Type: application/json

{"data": "in"}
```

Response:

```
Status: 503 SERVICE_UNAVAILABLE

Error: recvAddress(..) failed with error(-104): Connection reset by peer
```

Remediation

Ensure that all incoming data is strictly validated against the defined OpenAPI schema constraints (types, lengths, required fields) using a validation middleware before processing.

Reflected Cross-Site Scripting (XSS)

Severity:

MEDIUM

Base CVSS Score:
6.1

CWE: CWE_79
CAPEC Reference: CAPEC-63
OWASP: A05:2025 - Injection
Attack Vector: API Endpoint (Network)
Technical Impact: Unauthorized Access / Data Exposure

Endpoint: GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/patients/{id}/appointments

Description

The endpoint reflects unencoded user input from Query Parameter 'size' into the response.

Evidence

Response contains the exact unencoded XSS payload. The response is not HTML, so the script won't execute directly in modern browsers, but could be dangerous if a frontend incorrectly inserts this JSON data into the DOM.

Request:

```
GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/patients/59/appointments?size=<script>alert('XSS_VULNAPI_TEST')</script>&endDate=dolorum&startDate=amet
```

Response:

```
Status: 400 BAD_REQUEST
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Content-Length: 176
Content-Security-Policy: default-src 'self' https;; font-src 'self' https: data;; img-src 'self' https: data;; object-src 'none'; script-src https;; style-src 'self' https: 'unsafe-inline'
Content-Type: text/plain;charset=UTF-8
Date: Sat, 06 Jun 2026 13:23:02 GMT
Expires: 0
Pragma: no-cache
Referrer-Policy: no-referrer
Strict-Transport-Security: max-age=631138519
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
X-Content-Type-Options: nosniff
X-Correlation-Id: 05574b80a6c95e3d28c172574134d8d3
X-Download-Options: noopen
X-Frame-Options: DENY
X-Permitted-Cross-Domain-Policies: none
X-Ratelimit-Burst-Capacity: 150
X-Ratelimit-Remaining: 28
X-Ratelimit-Replenish-Rate: 100
X-Ratelimit-Requested-Tokens: 1
X-Xss-Protection: 0

Method parameter 'size': Failed to convert value of type 'java.lang.String' to required type 'java.lang.Integer'; For input string: "<script>alert('XSS_VULNAPI_TEST')</script>"
```

Remediation

Contextually encode user input before reflecting it in responses. Ensure the Content-Type header is strictly set to application/json for APIs.

Verbose Error Information Leak

Severity:

MEDIUM

Base CVSS Score:

5.3

CWE:

CWE_209

CAPEC Reference:

CAPEC-54

OWASP:

A02:2025 - Security Misconfiguration

Attack Vector:

API Endpoint (Network)

Technical Impact:

Unauthorized Access / Data Exposure

Endpoint: GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/patients/{id}/appointments

Description

The endpoint returns detailed error messages or stack traces when processing invalid input.

Evidence

Response contains stack traces or framework-specific internal errors after sending malformed or type-mismatched query parameters.

Request:

```
GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/patients/59/appointments?size=not_a_number_'[]{}&endDate=dolorum%00%ff'"&startDate=amet%00%ff'"
```

Response:

```
Status: 400 BAD_REQUEST
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Content-Length: 153
Content-Security-Policy: default-src 'self' https;; font-src 'self' https: data;; img-src 'self' https: data;; object-src 'none'; script-src https;; style-src 'self' https: 'unsafe-inline'
Content-Type: text/plain;charset=UTF-8
Date: Sat, 06 Jun 2026 13:23:03 GMT
Expires: 0
Pragma: no-cache
Referrer-Policy: no-referrer
Strict-Transport-Security: max-age=631138519
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
X-Content-Type-Options: nosniff
X-Correlation-Id: 5789d778320a4fecb68c266dfad6f2dc
X-Download-Options: noopen
X-Frame-Options: DENY
X-Permitted-Cross-Domain-Policies: none
X-Ratelimit-Burst-Capacity: 150
X-Ratelimit-Remaining: 58
X-Ratelimit-Replenish-Rate: 100
X-Ratelimit-Requested-Tokens: 1
X-Xss-Protection: 0

Method parameter 'size': Failed to convert value of type 'java.lang.String' to required type 'java.lang.Integer'; For input string: "not_a_number_'[]{}"
```

Remediation

Configure your framework to return generic error messages to the client. Log detailed errors internally only.

Verbose Error Information Leak

Severity:

MEDIUM

Base CVSS Score:

5.3

CWE:

CWE_209

CAPEC Reference:

CAPEC-54

OWASP:

A02:2025 - Security Misconfiguration

Attack Vector:

API Endpoint (Network)

Technical Impact:

Unauthorized Access / Data Exposure

Endpoint: GET <https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments>

Description

The endpoint returns detailed error messages or stack traces when processing invalid input.

Evidence

Response contains stack traces or framework-specific internal errors after sending malformed or type-mismatched query parameters.

Request:

```
GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments?appointmentType=deleniti%00%ff'"&participantActorId=dignissimos%00%ff'"&trajectoryAdmissionState=eos%00%ff'"&participantType=magni%00%ff'"&start=quam%00%ff'"&removeCancelled=true%00%ff'"&singlePatient=true%00%ff'"&patientAdmissionState=error%00%ff'"&size=not_a_number_'[]{}&excludePending=true%00%ff'"&end=quasi%00%ff'"&page=not_a_number_'[]{}&excludeWithoutPatient=true%00%ff'"&medicalServiceId=not_a_number_'[]{}&status=quis%00%ff'"&order=ut%00%ff'"
```

Response:

```
Status: 400 BAD_REQUEST
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Content-Length: 386
Content-Security-Policy: default-src 'self' https;; font-src 'self' https: data;; img-src 'self' https: data;; object-src 'none'; script-src https;; style-src 'self' https: 'unsafe-inline'
Content-Type: text/plain;charset=UTF-8
Date: Sat, 06 Jun 2026 13:23:03 GMT
Expires: 0
Pragma: no-cache
Referrer-Policy: no-referrer
Strict-Transport-Security: max-age=631138519
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
X-Content-Type-Options: nosniff
X-Correlation-Id: a3777d487cdf1c996ba2c8baa5ed1e07
X-Download-Options: noopen
X-Frame-Options: DENY
X-Permitted-Cross-Domain-Policies: none
X-Ratelimit-Burst-Capacity: 150
X-Ratelimit-Remaining: 50
X-Ratelimit-Replenish-Rate: 100
X-Ratelimit-Requested-Tokens: 1
X-Xss-Protection: 0

Method parameter 'participantType': Failed to convert value of type 'java.lang.String' to required type 'ch.hcuge.service.appointment.enums.ParticipantType'; Failed to convert from type [java.lang.String] to type [@org.springframework.web.bind.annotation.RequestParam @io.swagger.v3.oas.annotations.Parameter ch.hcuge.service.appointment.enums.ParticipantType] for value [magni%00%ff']"
```

Remediation

Configure your framework to return generic error messages to the client. Log detailed errors internally only.

Improper Input Validation (Missing Parameter Max Length (Unbounded))

Severity:

MEDIUM

Base CVSS Score:

5.3

CWE: CWE_20

CAPEC Reference: CAPEC-3

OWASP: A05:2025 - Injection

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: GET <https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments>

Description

Parameter 'participantType' lacks a maxLength constraint. An abnormally large string (50 KB) was accepted, potential DoS.

Evidence

The server responded with 503 SERVICE_UNAVAILABLE instead of enforcing the schema constraint (should be 400).

Request:

```
GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments?appointmentType=deleniti&participantAc
torId=dignissimos&trajectoryAdmissionState=eos&participantType=AAAAAAAAAAAAAAAAAAAAAAAAAAAAAA
AAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAA
AAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAA
... [TRUNCATED]&start=quam&removeCance
lled=true&singlePatient=true&patientAdmissionState=error&size=72&excludePending=true&end=quasi&page=
69&excludeWithoutPatient=true&medicalServiceId=28&status=quis&order=ut
```

Response:

Status: 503 SERVICE_UNAVAILABLE

```
Error: recvAddress(..) failed with error(-104): Connection reset by peer
```

Remediation

Ensure that all incoming data is strictly validated against the defined OpenAPI schema constraints (types, lengths, required fields) using a validation middleware before processing.

Improper Input Validation (Missing Parameter Max Length (Unbounded))

Severity:

MEDIUM

Base CVSS Score:

5.3

CWE: CWE_20

CAPEC Reference: CAPEC-3

OWASP: A05:2025 - Injection

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: GET <https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments>

Description

Parameter 'patientAdmissionState' lacks a maxLength constraint. An abnormally large string (50 KB) was accepted, potential DoS.

Evidence

The server responded with 503 SERVICE_UNAVAILABLE instead of enforcing the schema constraint (should be 400).

Request:

GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments?appointmentType=deleniti&participantActorId=dignissimos&trajectoryAdmissionState=eos&participantType=magni&start=quam&removeCancelled=true&singlePatient=true&patientAdmissionState=AA... [TRUNCATED]&size=72&excludePending=true&end=quasi&page=69&excludeWithoutPatient=true&medicalServiceId=28&status=quis&order=ut

Response:

Status: 503 SERVICE_UNAVAILABLE

```
Error: recvAddress(..) failed with error(-104): Connection reset by peer
```

Remediation

Ensure that all incoming data is strictly validated against the defined OpenAPI schema constraints (types, lengths, required fields) using a validation middleware before processing.

Improper Input Validation (Missing Parameter Max Length (Unbounded))

Severity:

MEDIUM

Base CVSS Score:

5.3

CWE: CWE_20

CAPEC Reference: CAPEC-3

OWASP: A05:2025 - Injection

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: GET <https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments>

Description

Parameter 'participantActorId' lacks a maxLength constraint. An abnormally large string (50 KB) was accepted, potential DoS.

Evidence

The server responded with 503 SERVICE_UNAVAILABLE instead of enforcing the schema constraint (should be 400).

Request:

GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments?appointmentType=deleniti&participantActorId=AA
AAAAA...[TRUNCATED]&trajectoryAdmissionState=eos&participantType=magni&start=quam&removeCancelled=true&singlePatient=true&patientAdmissionState=error&size=72&excludePending=true&end=quasi&page=69&excl
udeWithoutPatient=true&medicalServiceId=28&status=quis&order=ut

Response:

Status: 503 SERVICE_UNAVAILABLE

```
Error: recvAddress(..) failed with error(-104): Connection reset by peer
```

Remediation

Ensure that all incoming data is strictly validated against the defined OpenAPI schema constraints (types, lengths, required fields) using a validation middleware before processing.

Improper Input Validation (Missing Parameter Max Length (Unbounded))

Severity:

MEDIUM

Base CVSS Score:

5.3

CWE: CWE_20

CAPEC Reference: CAPEC-3

OWASP: A05:2025 - Injection

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: GET <https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments>

Description

Parameter 'start' lacks a maxLength constraint. An abnormally large string (50 KB) was accepted, potential DoS.

Evidence

The server responded with 503 SERVICE_UNAVAILABLE instead of enforcing the schema constraint (should be 400).

Request:

GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments?appointmentType=deleniti&participantActorId=dignissimos&trajectoryAdmissionState=eos&participantType=magni&start=AAAAAAAAAAAAAAAAAAAAAA
AA... [TRUNCATED]&removeCancelled=true&singlePatient=true&patientAdmissionState=error&size=72&excludePending=true&end=quasi&page=69&excludeWithoutPatient=true&medicalServiceId=28&status=quis&order=ut

Response:

Status: 503 SERVICE_UNAVAILABLE

```
Error: recvAddress(..) failed with error(-104): Connection reset by peer
```

Remediation

Ensure that all incoming data is strictly validated against the defined OpenAPI schema constraints (types, lengths, required fields) using a validation middleware before processing.

Improper Input Validation (Missing Parameter Max Length (Unbounded))

Severity:

MEDIUM

Base CVSS Score:

5.3

CWE: CWE_20

CAPEC Reference: CAPEC-3

OWASP: A05:2025 - Injection

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: GET <https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments>

Description

Parameter 'end' lacks a maxLength constraint. An abnormally large string (50 KB) was accepted, potential DoS.

Evidence

The server responded with 503 SERVICE_UNAVAILABLE instead of enforcing the schema constraint (should be 400).

Request:

GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments?appointmentType=deleniti&participantActorId=dignissimos&trajectoryAdmissionState=eos&participantType=magni&start=quam&removeCancelled=true&singlePatient=true&patientAdmissionState=error&size=72&excludePending=true&end=AAAAAAAAAAAAAAAAAAAAA
AA... [TRUNCATED]
&page=69&excludeWithoutPatient=true&medicalServiceId=28&status=quis&order=ut

Response:

Status: 503 SERVICE_UNAVAILABLE

```
Error: recvAddress(..) failed with error(-104): Connection reset by peer
```

Remediation

Ensure that all incoming data is strictly validated against the defined OpenAPI schema constraints (types, lengths, required fields) using a validation middleware before processing.

Improper Input Validation (Missing Parameter Max Length (Unbounded))

Severity:

MEDIUM

Base CVSS Score:

5.3

CWE: CWE_20

CAPEC Reference: CAPEC-3

OWASP: A05:2025 - Injection

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments

Description

Parameter 'appointmentType' lacks a maxLength constraint. An abnormally large string (50 KB) was accepted, potential DoS.

Evidence

The server responded with 503 SERVICE_UNAVAILABLE instead of enforcing the schema constraint (should be 400).

Request:

```
GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments?appointmentType=AAAAAAAAAAAAAAAAAAAA
AAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAA...[TRUNCATED]&partici
pantActorId=dignissimos&trajectoryAdmissionState=eos&participantType=magni&start=quam&removeCancelle
d=true&singlePatient=true&patientAdmissionState=error&size=72&excludePending=true&end=quasi&page=69&
excludeWithoutPatient=true&medicalServiceId=28&status=quis&order=ut
```

Response:

```
Status: 503 SERVICE_UNAVAILABLE

Error: recvAddress(..) failed with error(-104): Connection reset by peer
```

Remediation

Ensure that all incoming data is strictly validated against the defined OpenAPI schema constraints (types, lengths, required fields) using a validation middleware before processing.

Improper Input Validation (Missing Parameter Max Length (Unbounded))

Severity:

MEDIUM

Base CVSS Score:

5.3

CWE: CWE_20

CAPEC Reference: CAPEC-3

OWASP: A05:2025 - Injection

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: GET <https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments>

Description

Parameter 'status' lacks a maxLength constraint. An abnormally large string (50 KB) was accepted, potential DoS.

Evidence

The server responded with 503 SERVICE_UNAVAILABLE instead of enforcing the schema constraint (should be 400).

Request:

[illegible]

Response:

Status: 503 SERVICE_UNAVAILABLE

```
Error: recvAddress(..) failed with error(-104): Connection reset by peer
```

Remediation

Ensure that all incoming data is strictly validated against the defined OpenAPI schema constraints (types, lengths, required fields) using a validation middleware before processing.

Improper Input Validation (Missing Parameter Max Length (Unbounded))

Severity:

MEDIUM

Base CVSS Score:

5.3

CWE: CWE_20

CAPEC Reference: CAPEC-3

OWASP: A05:2025 - Injection

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: GET <https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments>

Description

Parameter 'trajectoryAdmissionState' lacks a maxLength constraint. An abnormally large string (50 KB) was accepted, potential DoS.

Evidence

The server responded with 503 SERVICE_UNAVAILABLE instead of enforcing the schema constraint (should be 400).

Request:

```
GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments?appointmentType=deleniti&participantAc  
torId=dignissimos&trajectoryAdmissionState=AAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAA  
AAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAA...[TRUNCATED]&participantType=magni&start=quam&removeCan  
celled=true&singlePatient=true&patientAdmissionState=error&size=72&excludePending=true&end=quasi&pag  
e=69&excludeWithoutPatient=true&medicalServiceId=28&status=quis&order=ut
```

Response:

Status: 503 SERVICE_UNAVAILABLE

```
Error: recvAddress(..) failed with error(-104): Connection reset by peer
```

Remediation

Ensure that all incoming data is strictly validated against the defined OpenAPI schema constraints (types, lengths, required fields) using a validation middleware before processing.

Improper Input Validation (Missing Parameter Max Length (Unbounded))

Severity:

MEDIUM

Base CVSS Score:

5.3

CWE: CWE_20

CAPEC Reference: CAPEC-3

OWASP: A05:2025 - Injection

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: GET <https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments>

Description

Parameter 'order' lacks a maxLength constraint. An abnormally large string (50 KB) was accepted, potential DoS.

Evidence

The server responded with 503 SERVICE_UNAVAILABLE instead of enforcing the schema constraint (should be 400).

Request:

[illegible]

Response:

Status: 503 SERVICE_UNAVAILABLE

```
Error: recvAddress(..) failed with error(-104): Connection reset by peer
```

Remediation

Ensure that all incoming data is strictly validated against the defined OpenAPI schema constraints (types, lengths, required fields) using a validation middleware before processing.

Improper Input Validation (Missing Parameter Max Length (Unbounded))

Severity:

MEDIUM

Base CVSS Score:

5.3

CWE: CWE_20

CAPEC Reference: CAPEC-3

OWASP: A05:2025 - Injection

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: GET <https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/patients/{id}/appointments>

Description

Parameter 'endDate' lacks a maxLength constraint. An abnormally large string (50 KB) was accepted, potential DoS.

Evidence

The server responded with 503 SERVICE_UNAVAILABLE instead of enforcing the schema constraint (should be 400).

Request:

```
GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/patients/59/appointments?size=44&endDate=AAAAAAAAA
AAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAA...
[TRUNCATED]&startDate=amet
```

Response:

Status: 503 SERVICE_UNAVAILABLE

Error: recvAddress(..) failed with error(-104): Connection reset by peer

Remediation

Ensure that all incoming data is strictly validated against the defined OpenAPI schema constraints (types, lengths, required fields) using a validation middleware before processing.

Improper Input Validation (Missing Parameter Max Length (Unbounded))

Severity:

MEDIUM

Base CVSS Score:

5.3

CWE: CWE_20

CAPEC Reference: CAPEC-3

OWASP: A05:2025 - Injection

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: GET <https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/patients/{id}/appointments>

Description

Parameter 'startDate' lacks a maxLength constraint. An abnormally large string (50 KB) was accepted, potential DoS.

Evidence

The server responded with 503 SERVICE_UNAVAILABLE instead of enforcing the schema constraint (should be 400).

Request:

[illegible]

Response:

Status: 503 SERVICE_UNAVAILABLE

```
Error: recvAddress(..) failed with error(-104): Connection reset by peer
```

Remediation

Ensure that all incoming data is strictly validated against the defined OpenAPI schema constraints (types, lengths, required fields) using a validation middleware before processing.

Verbose Error Information Leak

Severity:

MEDIUM

Base CVSS Score:

5.3

CWE: CWE 209

CAPEC Reference: CAPEC-54

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: DELETE <https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/{id}>

Description

The endpoint returns detailed error messages or stack traces when processing invalid input.

Evidence

Response contains stack traces or framework-specific internal errors after sending malformed or type-mismatched query parameters.

Request:

```
DELETE https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/43?recurrenceDeleteOption=illo%00%ff'"
Content-Type: application/json

{"data": "in"}
```

Response:

```
Status: 400 BAD_REQUEST
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Content-Length: 408
Content-Security-Policy: default-src 'self' https;; font-src 'self' https: data;; img-src 'self' https: data;; object-src 'none'; script-src https;; style-src 'self' https: 'unsafe-inline'
Content-Type: text/plain;charset=UTF-8
Date: Sat, 06 Jun 2026 13:23:04 GMT
Expires: 0
Pragma: no-cache
Referrer-Policy: no-referrer
Strict-Transport-Security: max-age=631138519
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
X-Content-Type-Options: nosniff
X-Correlation-Id: a3b61fe5fe1bdde65780d9ad494f9357
X-Download-Options: noopen
X-Frame-Options: DENY
X-Permitted-Cross-Domain-Policies: none
X-Ratelimit-Burst-Capacity: 150
X-Ratelimit-Remaining: 60
X-Ratelimit-Replenish-Rate: 100
X-Ratelimit-Requested-Tokens: 1
X-Xss-Protection: 0

Method parameter 'recurrenceDeleteOption': Failed to convert value of type 'java.lang.String' to required type 'ch.hcuge.service.appointment.enums.PeriodicityUpdateOption'; Failed to convert from type [java.lang.String] to type [@org.springframework.web.bind.annotation.RequestParam @io.swagger.v3.oas.annotations.Parameter ch.hcuge.service.appointment.enums.PeriodicityUpdateOption] for value [illo%00%ff"]
```

Remediation

Configure your framework to return generic error messages to the client. Log detailed errors internally only.

Reflected Cross-Site Scripting (XSS)

Severity:

MEDIUM

Base CVSS Score:
6.1

CWE: CWE_79
CAPEC Reference: CAPEC-63
OWASP: A05:2025 - Injection
Attack Vector: API Endpoint (Network)
Technical Impact: Unauthorized Access / Data Exposure

Endpoint: DELETE `https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/{id}`

Description

The endpoint reflects unencoded user input from Query Parameter 'recurrenceDeleteOption' into the response.

Evidence

Response contains the exact unencoded XSS payload. The response is not HTML, so the script won't execute directly in modern browsers, but could be dangerous if a frontend incorrectly inserts this JSON data into the DOM.

Request:

```
DELETE https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/43?
recurrenceDeleteOption=<script>alert('XSS_VULNAPI_TEST')</script>
Content-Type: application/json

{"data": "in"}
```

Response:

```
Status: 400 BAD_REQUEST
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Content-Length: 438
Content-Security-Policy: default-src 'self' https;; font-src 'self' https: data;; img-src 'self' https: data;; object-src 'none'; script-src https;; style-src 'self' https: 'unsafe-inline'
Content-Type: text/plain;charset=UTF-8
Date: Sat, 06 Jun 2026 13:23:04 GMT
Expires: 0
Pragma: no-cache
Referrer-Policy: no-referrer
Strict-Transport-Security: max-age=631138519
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
X-Content-Type-Options: nosniff
X-Correlation-Id: b3afd1db00f589636d9438218a3b366e
X-Download-Options: noopen
X-Frame-Options: DENY
X-Permitted-Cross-Domain-Policies: none
X-Ratelimit-Burst-Capacity: 150
X-Ratelimit-Remaining: 57
X-Ratelimit-Replenish-Rate: 100
X-Ratelimit-Requested-Tokens: 1
X-Xss-Protection: 0

Method parameter 'recurrenceDeleteOption': Failed to convert value of type 'java.lang.String' to required type 'ch.hcuge.service.appointment.enums.PeriodicityUpdateOption'; Failed to convert from type [java.lang.String] to type [@org.springframework.web.bind.annotation.RequestParam @io.swagger.v3.oas.annotations.Parameter ch.hcuge.service.appointment.enums.PeriodicityUpdateOption] for value [<script>alert('XSS_VULNAPI_TEST')</script>]
```

Remediation

Contextually encode user input before reflecting it in responses. Ensure the Content-Type header is strictly set to application/json for APIs.

Reflected Cross-Site Scripting (XSS)

Severity:

MEDIUM

Base CVSS Score:

6.1

CWE: CWE_79

CAPEC Reference: CAPEC-63

OWASP: A05:2025 - Injection

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint:

GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/persons/{personId}/appointments

Description

The endpoint reflects unencoded user input from Query Parameter 'size' into the response.

Evidence

Response contains the exact unencoded XSS payload. The response is not HTML, so the script won't execute directly in modern browsers, but could be dangerous if a frontend incorrectly inserts this JSON data into the DOM.

Request:

```
GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/persons/officia/appointments?size=<script>alert('XSS_VULNAPI_TEST')</script>&endDate=architecto&activityModelId=96&startDate=nihil
```

Response:

```
Status: 400 BAD_REQUEST
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Content-Length: 176
Content-Security-Policy: default-src 'self' https;; font-src 'self' https: data;; img-src 'self' https: data;; object-src 'none'; script-src https;; style-src 'self' https: 'unsafe-inline'
Content-Type: text/plain;charset=UTF-8
Date: Sat, 06 Jun 2026 13:23:04 GMT
Expires: 0
Pragma: no-cache
Referrer-Policy: no-referrer
Strict-Transport-Security: max-age=631138519
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
X-Content-Type-Options: nosniff
X-Correlation-Id: dffc4a6f67c8fd827c5f5d42fdb68e6e
X-Download-Options: noopen
X-Frame-Options: DENY
X-Permitted-Cross-Domain-Policies: none
X-Ratelimit-Burst-Capacity: 150
X-Ratelimit-Remaining: 5
X-Ratelimit-Replenish-Rate: 100
X-Ratelimit-Requested-Tokens: 1
X-Xss-Protection: 0

Method parameter 'size': Failed to convert value of type 'java.lang.String' to required type 'java.lang.Integer'; For input string: "<script>alert('XSS_VULNAPI_TEST')</script>"
```

Remediation

Contextually encode user input before reflecting it in responses. Ensure the Content-Type header is strictly set to application/json for APIs.

Weak Security Header: CSP

Severity:

MEDIUM

Base CVSS Score:
5.4

CWE: CWE_693
CAPEC Reference: CAPEC-63
OWASP: A02:2025 - Security Misconfiguration
Attack Vector: API Endpoint (Network)
Technical Impact: Unauthorized Access / Data Exposure

Endpoint: GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/v1.0/user/appointments/conflict

Description

The Content-Security-Policy header contains 'unsafe-inline' or 'unsafe-eval', which significantly reduces the protection against XSS attacks.

Evidence

CSP value contains unsafe directives: default-src 'self' https;; font-src 'self' https: data;; img-src 'self' https: data;; object-src 'none'; script-src https;; style-src 'self' https: 'unsafe-inline'

Request:

```
GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/v1.0/user/appointments/conflict?
endDate=a&startDate=vitae
```

Response:

```
Status: 400 BAD_REQUEST
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Content-Length: 372
Content-Security-Policy: default-src 'self' https;; font-src 'self' https: data;; img-src 'self'
https: data;; object-src 'none'; script-src https;; style-src 'self' https: 'unsafe-inline'
Content-Type: text/plain;charset=UTF-8
Date: Sat, 06 Jun 2026 13:23:04 GMT
Expires: 0
Pragma: no-cache
Referrer-Policy: no-referrer
Strict-Transport-Security: max-age=631138519
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
X-Content-Type-Options: nosniff
X-Correlation-Id: c8607e0e63b1041a94baf3404b98a805
X-Download-Options: noopen
X-Frame-Options: DENY
X-Permitted-Cross-Domain-Policies: none
X-Ratelimit-Burst-Capacity: 150
X-Ratelimit-Remaining: 10
X-Ratelimit-Replenish-Rate: 100
X-Ratelimit-Requested-Tokens: 1
X-Xss-Protection: 0
```

```
Method parameter 'startDate': Failed to convert value of type 'java.lang.String' to required type
'java.time.ZonedDateTime'; Failed to convert from type [java.lang.String] to type [org.
springframework.web.bind.annotation.RequestParam @io.swagger.v3.oas.annotations.Parameter @org.
springframework.format.annotation.DateTimeFormat java.time.ZonedDateTime] for value [vitae]
```

Remediation

Remove 'unsafe-inline' and 'unsafe-eval' from your CSP and use nonces or hashes instead.

Improper Input Validation (Missing Parameter Max Length (Unbounded))

Severity:

MEDIUM

Base CVSS Score:

5.3

CWE: CWE_20

CAPEC Reference: CAPEC-3

OWASP: A05:2025 - Injection

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: GET <https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/v1.0/user/appointments/conflict>

Description

Parameter 'endDate' lacks a maxLength constraint. An abnormally large string (50 KB) was accepted, potential DoS.

Evidence

The server responded with 503 SERVICE_UNAVAILABLE instead of enforcing the schema constraint (should be 400).

Request:

```
GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/v1.0/user/appointments/conflict?endDate=AAAAAAAAAA
AAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAA...
[TRUNCATED]&startDate=vitae
```

Response:

Status: 503 SERVICE_UNAVAILABLE

Error: recvAddress(..) failed with error(-104): Connection reset by peer

Remediation

Ensure that all incoming data is strictly validated against the defined OpenAPI schema constraints (types, lengths, required fields) using a validation middleware before processing.

Improper Input Validation (Missing Parameter Max Length (Unbounded))

Severity:

MEDIUM

Base CVSS Score:

5.3

CWE: CWE_20

CAPEC Reference: CAPEC-3

OWASP: A05:2025 - Injection

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: GET <https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/v1.0/user/appointments/conflict>

Description

Parameter 'startDate' lacks a maxLength constraint. An abnormally large string (50 KB) was accepted, potential DoS.

Evidence

The server responded with 503 SERVICE_UNAVAILABLE instead of enforcing the schema constraint (should be 400).

Request:

[illegible]

Response:

Status: 503 SERVICE_UNAVAILABLE

```
Error: recvAddress(..) failed with error(-104): Connection reset by peer
```

Remediation

Ensure that all incoming data is strictly validated against the defined OpenAPI schema constraints (types, lengths, required fields) using a validation middleware before processing.

Reflected Cross-Site Scripting (XSS)

Severity:

MEDIUM

Base CVSS Score:

6.1

CWE: CWE 79

CAPEC Reference: CAPEC-63

OWASP: A05:2025 - Injection

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: GET <https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments>

Description

The endpoint reflects unencoded user input from Query Parameter 'participantType' into the response.

Evidence

Response contains the exact unencoded XSS payload. The response is not HTML, so the script won't execute directly in modern browsers, but could be dangerous if a frontend incorrectly inserts this JSON data into the DOM.

Request:

```
GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments?appointmentType=deleniti&participantActorId=dignissimos&trajectoryAdmissionState=eos&participantType=<script>alert('XSS_VULNAPI_TEST')</script>&start=quam&removeCancelled=true&singlePatient=true&patientAdmissionState=error&size=72&excludePending=true&end=quasi&page=69&excludeWithoutPatient=true&medicalServiceId=28&status=quis&order=ut
```

Response:

```
Status: 400 BAD_REQUEST
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Content-Length: 415
Content-Security-Policy: default-src 'self' https;; font-src 'self' https: data:; img-src 'self' https: data:; object-src 'none'; script-src https;; style-src 'self' https: 'unsafe-inline'
Content-Type: text/plain;charset=UTF-8
Date: Sat, 06 Jun 2026 13:23:07 GMT
Expires: 0
Pragma: no-cache
Referrer-Policy: no-referrer
Strict-Transport-Security: max-age=631138519
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
X-Content-Type-Options: nosniff
X-Correlation-Id: ec8b0606c3892e00591bbfc9f3b11d1a
X-Download-Options: noopen
X-Frame-Options: DENY
X-Permitted-Cross-Domain-Policies: none
X-Ratelimit-Burst-Capacity: 150
X-Ratelimit-Remaining: 84
X-Ratelimit-Replenish-Rate: 100
X-Ratelimit-Requested-Tokens: 1
X-Xss-Protection: 0

Method parameter 'participantType': Failed to convert value of type 'java.lang.String' to required type 'ch.hcuge.service.appointment.enums.ParticipantType'; Failed to convert from type [java.lang.String] to type [@org.springframework.web.bind.annotation.RequestParam @io.swagger.v3.oas.annotations.Parameter ch.hcuge.service.appointment.enums.ParticipantType] for value [<script>alert('XSS_VULNAPI_TEST')</script>]
```

Remediation

Contextually encode user input before reflecting it in responses. Ensure the Content-Type header is strictly set to application/json for APIs.

Verbose Error Information Leak

Severity:

MEDIUM

Base CVSS Score:

5.3

CWE:

CWE_209

CAPEC Reference:

CAPEC-54

OWASP:

A02:2025 - Security Misconfiguration

Attack Vector:

API Endpoint (Network)

Technical Impact:

Unauthorized Access / Data Exposure

Endpoint:

GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/v1.0/user/appointments/conflict

Description

The endpoint returns detailed error messages or stack traces when processing invalid input.

Evidence

Response contains stack traces or framework-specific internal errors after sending malformed or type-mismatched query parameters.

Request:

```
GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/v1.0/user/appointments/conflict?endDate=a%00%ff'"&startDate=vitae%00%ff'"
```

Response:

```
Status: 400 BAD_REQUEST
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Content-Length: 380
Content-Security-Policy: default-src 'self' https;; font-src 'self' https: data:; img-src 'self' https: data:; object-src 'none'; script-src https;; style-src 'self' https: 'unsafe-inline'
Content-Type: text/plain;charset=UTF-8
Date: Sat, 06 Jun 2026 13:23:07 GMT
Expires: 0
Pragma: no-cache
Referrer-Policy: no-referrer
Strict-Transport-Security: max-age=631138519
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
X-Content-Type-Options: nosniff
X-Correlation-Id: 2dbd6848cef8675189e72fd611883246
X-Download-Options: noopen
X-Frame-Options: DENY
X-Permitted-Cross-Domain-Policies: none
X-Ratelimit-Burst-Capacity: 150
X-Ratelimit-Remaining: 46
X-Ratelimit-Replenish-Rate: 100
X-Ratelimit-Requested-Tokens: 1
X-Xss-Protection: 0
```

```
Method parameter 'startDate': Failed to convert value of type 'java.lang.String' to required type 'java.time.ZonedDateTime'; Failed to convert from type [java.lang.String] to type [@org.springframework.web.bind.annotation.RequestParam @io.swagger.v3.oas.annotations.Parameter @org.springframework.format.annotation.DateTimeFormat java.time.ZonedDateTime] for value [vitae%00%ff']"
```

Remediation

Configure your framework to return generic error messages to the client. Log detailed errors internally only.

Reflected Cross-Site Scripting (XSS)

Severity:	Base CVSS Score:	CWE: CWE_79
MEDIUM	6.1	CAPEC Reference: CAPEC-63
		OWASP: A05:2025 - Injection
		Attack Vector: API Endpoint (Network)
		Technical Impact: Unauthorized Access / Data Exposure

Endpoint: GET <https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/v1.0/user/appointments/conflict>

Description

The endpoint reflects unencoded user input from Query Parameter 'startDate' into the response.

Evidence

Response contains the exact unencoded XSS payload. The response is not HTML, so the script won't execute directly in modern browsers, but could be dangerous if a frontend incorrectly inserts this JSON data into the DOM.

Request:

```
GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/v1.0/user/appointments/conflict?
endDate=a&startDate=<script>alert('XSS_VULNAPI_TEST')</script>
```

Response:

```
Status: 400 BAD_REQUEST
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Content-Length: 409
Content-Security-Policy: default-src 'self' https;; font-src 'self' https: data;; img-src 'self'
https: data;; object-src 'none'; script-src https;; style-src 'self' https: 'unsafe-inline'
Content-Type: text/plain;charset=UTF-8
Date: Sat, 06 Jun 2026 13:23:07 GMT
Expires: 0
Pragma: no-cache
Referrer-Policy: no-referrer
Strict-Transport-Security: max-age=631138519
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
X-Content-Type-Options: nosniff
X-Correlation-Id: c4557b75c03fa0993b79108e29111d4b
X-Download-Options: noopen
X-Frame-Options: DENY
X-Permitted-Cross-Domain-Policies: none
X-Ratelimit-Burst-Capacity: 150
X-Ratelimit-Remaining: 43
X-Ratelimit-Replenish-Rate: 100
X-Ratelimit-Requested-Tokens: 1
X-Xss-Protection: 0

Method parameter 'startDate': Failed to convert value of type 'java.lang.String' to required type
'java.time.ZonedDateTime'; Failed to convert from type [java.lang.String] to type [org.
springframework.web.bind.annotation.RequestParam @io.swagger.v3.oas.annotations.Parameter @org.
springframework.format.annotation.DateTimeFormat java.time.ZonedDateTime] for value [<script>alert
('XSS_VULNAPI_TEST')</script>]
```

Remediation

Contextually encode user input before reflecting it in responses. Ensure the Content-Type header is strictly set to application/json for APIs.

Verbose Error Information Leak

Severity:

MEDIUM

Base CVSS Score:

5.3

CWE:

CWE_209

CAPEC Reference:

CAPEC-54

OWASP:

A02:2025 - Security Misconfiguration

Attack Vector:

API Endpoint (Network)

Technical Impact:

Unauthorized Access / Data Exposure

Endpoint:

GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/practitioners/{practitionerId}/location

Description

The endpoint returns detailed error messages or stack traces when processing invalid input.

Evidence

Response contains stack traces or framework-specific internal errors after sending malformed or type-mismatched query parameters.

Request:

```
GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/practitioners/81/location?searchDate=in%00%ff'"
```

Response:

```
Status: 400 BAD_REQUEST
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Content-Length: 378
Content-Security-Policy: default-src 'self' https;; font-src 'self' https: data:; img-src 'self' https: data:; object-src 'none'; script-src https;; style-src 'self' https: 'unsafe-inline'
Content-Type: text/plain;charset=UTF-8
Date: Sat, 06 Jun 2026 13:23:09 GMT
Expires: 0
Pragma: no-cache
Referrer-Policy: no-referrer
Strict-Transport-Security: max-age=631138519
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
X-Content-Type-Options: nosniff
X-Correlation-Id: 6e4b3832db8f8374e9756b1b1b436b3a
X-Download-Options: noopen
X-Frame-Options: DENY
X-Permitted-Cross-Domain-Policies: none
X-Ratelimit-Burst-Capacity: 150
X-Ratelimit-Remaining: 15
X-Ratelimit-Replenish-Rate: 100
X-Ratelimit-Requested-Tokens: 1
X-Xss-Protection: 0

Method parameter 'searchDate': Failed to convert value of type 'java.lang.String' to required type 'java.time.ZonedDateTime'; Failed to convert from type [java.lang.String] to type [@org.springframework.web.bind.annotation.RequestParam @io.swagger.v3.oas.annotations.Parameter @org.springframework.format.annotation.DateTimeFormat java.time.ZonedDateTime] for value [in%00%ff']"
```

Remediation

Configure your framework to return generic error messages to the client. Log detailed errors internally only.

Reflected Cross-Site Scripting (XSS)

Severity:	Base CVSS Score:	CWE: CWE_79
MEDIUM	6.1	CAPEC Reference: CAPEC-63
		OWASP: A05:2025 - Injection
		Attack Vector: API Endpoint (Network)
		Technical Impact: Unauthorized Access / Data Exposure
Endpoint:	GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/practitioners/{practitionerId}/location	

Description

The endpoint reflects unencoded user input from Query Parameter 'searchDate' into the response.

Evidence

Response contains the exact unencoded XSS payload. The response is not HTML, so the script won't execute directly in modern browsers, but could be dangerous if a frontend incorrectly inserts this JSON data into the DOM.

Request:

```
GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/practitioners/81/location?searchDate=<script>alert('XSS_VULNAPI_TEST')</script>
```

Response:

```
Status: 400 BAD_REQUEST
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Content-Length: 410
Content-Security-Policy: default-src 'self' https;; font-src 'self' https: data;; img-src 'self' https: data;; object-src 'none'; script-src https;; style-src 'self' https: 'unsafe-inline'
Content-Type: text/plain;charset=UTF-8
Date: Sat, 06 Jun 2026 13:23:13 GMT
Expires: 0
Pragma: no-cache
Referrer-Policy: no-referrer
Strict-Transport-Security: max-age=631138519
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
X-Content-Type-Options: nosniff
X-Correlation-Id: 53a0d3714b9b4b859b55742395cd8229
X-Download-Options: noopen
X-Frame-Options: DENY
X-Permitted-Cross-Domain-Policies: none
X-Ratelimit-Burst-Capacity: 150
X-Ratelimit-Remaining: 78
X-Ratelimit-Replenish-Rate: 100
X-Ratelimit-Requested-Tokens: 1
X-Xss-Protection: 0

Method parameter 'searchDate': Failed to convert value of type 'java.lang.String' to required type 'java.time.ZonedDateTime'; Failed to convert from type [java.lang.String] to type [org.springframework.web.bind.annotation.RequestParam @io.swagger.v3.oas.annotations.Parameter @org.springframework.format.annotation.DateTimeFormat java.time.ZonedDateTime] for value [<script>alert('XSS_VULNAPI_TEST')</script>]
```

Remediation

Contextually encode user input before reflecting it in responses. Ensure the Content-Type header is strictly set to application/json for APIs.

Improper Input Validation (Parameter Type Violation)

Severity:

MEDIUM

Base CVSS Score:

5.3

CWE: CWE_20

CAPEC Reference: CAPEC-3

OWASP: A05:2025 - Injection

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: PATCH https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/{appointmentId}/patients/{patientId}/statu... [TRUNCATED]

Description

Parameter 'appointmentId' expects a number but accepted a string.

Evidence

The server responded with 503 SERVICE_UNAVAILABLE instead of enforcing the schema constraint (should be 400).

Request:

```
PATCH https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/invalid_string_not_number/patients/98/status-and-encounter
Content-Type: application/json

{"data": "officiis"}
```

Response:

```
Status: 503 SERVICE_UNAVAILABLE

Error: Rate limit exceeded (429)
```

Remediation

Ensure that all incoming data is strictly validated against the defined OpenAPI schema constraints (types, lengths, required fields) using a validation middleware before processing.

Missing Rate Limiting

Severity:

MEDIUM

Base CVSS Score:

5.3

CWE: CWE_799

CAPEC Reference: CAPEC-115

OWASP: A06:2025 - Insecure Design

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: **POST** `https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/recurrence`

Description

The endpoint does not seem to enforce rate limiting. 50 rapid requests were sent without receiving a 429 Too Many Requests response.

Evidence

After 50 requests, the server returned status 400 instead of 429.

Request:

```
POST https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/recurrence
Content-Type: application/json

{"data": "aliquid"}
```

Response:

No Response

Remediation

Implement rate limiting using a gateway, WAF, or application logic (e.g. token bucket algorithm).

Improper Input Validation (Missing Parameter Max Length (Unbounded))

Severity:

MEDIUM

Base CVSS Score:

5.3

CWE: CWE_20

CAPEC Reference: CAPEC-3

OWASP: A05:2025 - Injection

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: GET <https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/practitioners/{practitionerId}/location>

Description

Parameter 'searchDate' lacks a maxLength constraint. An abnormally large string (50 KB) was accepted, potential DoS.

Evidence

The server responded with 503 SERVICE_UNAVAILABLE instead of enforcing the schema constraint (should be 400).

Request:

```
GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/practitioners/81/location?searchDate=AAAAAAAAAAAAA
AAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAA... [TRUNCATED]
```

Response:

Status: 503 SERVICE_UNAVAILABLE

Error: recvAddress(..) failed with error(-104): Connection reset by peer

Remediation

Ensure that all incoming data is strictly validated against the defined OpenAPI schema constraints (types, lengths, required fields) using a validation middleware before processing.

Missing Rate Limiting

Severity:

MEDIUM

Base CVSS Score:

5.3

CWE: CWE_799

CAPEC Reference: CAPEC-115

OWASP: A06:2025 - Insecure Design

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: PATCH <https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/{id}>

Description

The endpoint does not seem to enforce rate limiting. 50 rapid requests were sent without receiving a 429 Too Many Requests response.

Evidence

After 50 requests, the server returned status 400 instead of 429.

Request:

```
PATCH https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/7?
recurrenceUpdateOption=non&autoVisit=true
Content-Type: application/json

{"data": "iusto"}
```

Response:

No Response

Remediation

Implement rate limiting using a gateway, WAF, or application logic (e.g. token bucket algorithm).

Missing Rate Limiting

Severity:

MEDIUM

Base CVSS Score:

5.3

CWE: CWE_799

CAPEC Reference: CAPEC-115

OWASP: A06:2025 - Insecure Design

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: DELETE <https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/{id}>

Description

The endpoint does not seem to enforce rate limiting. 50 rapid requests were sent without receiving a 429 Too Many Requests response.

Evidence

After 50 requests, the server returned status 400 instead of 429.

Request:

```
DELETE https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/43?recurrenceDeleteOption=illo
Content-Type: application/json

{"data": "in"}
```

Response:

No Response

Remediation

Implement rate limiting using a gateway, WAF, or application logic (e.g. token bucket algorithm).

Missing Rate Limiting

Severity:

MEDIUM

Base CVSS Score:

5.3

CWE: CWE_799

CAPEC Reference: CAPEC-115

OWASP: A06:2025 - Insecure Design

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: PUT <https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/{id}>

Description

The endpoint does not seem to enforce rate limiting. 50 rapid requests were sent without receiving a 429 Too Many Requests response.

Evidence

After 50 requests, the server returned status 400 instead of 429.

Request:

```
PUT https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/37?
recurrenceUpdateOption=maiores&autoVisit=true
Content-Type: application/json

{"data": "voluptas"}
```

Response:

No Response

Remediation

Implement rate limiting using a gateway, WAF, or application logic (e.g. token bucket algorithm).

Weak Security Header: CSP

Severity:

MEDIUM

Base CVSS Score:

5.4

CWE: CWE_693

CAPEC Reference: CAPEC-63

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: GET <https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/activity-canvas/{modelId}/appointments>

Description

The Content-Security-Policy header contains 'unsafe-inline' or 'unsafe-eval', which significantly reduces the protection against XSS attacks.

Evidence

CSP value contains unsafe directives: default-src 'self' https;; font-src 'self' https: data;; img-src 'self' https: data;; object-src 'none'; script-src https;; style-src 'self' https: 'unsafe-inline'

Request:

```
GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/activity-canvas/54/appointments?size=97&endDate=minus&excludePending=true&startDate=voluptate
```

Response:

```
Status: 400 BAD_REQUEST
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Content-Length: 376
Content-Security-Policy: default-src 'self' https;; font-src 'self' https: data;; img-src 'self' https: data;; object-src 'none'; script-src https;; style-src 'self' https: 'unsafe-inline'
Content-Type: text/plain;charset=UTF-8
Date: Sat, 06 Jun 2026 13:23:33 GMT
Expires: 0
Pragma: no-cache
Referrer-Policy: no-referrer
Strict-Transport-Security: max-age=631138519
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
X-Content-Type-Options: nosniff
X-Correlation-Id: 7f4c9a0d053f16dbb2720fd31625df3e
X-Download-Options: noopen
X-Frame-Options: DENY
X-Permitted-Cross-Domain-Policies: none
X-Ratelimit-Burst-Capacity: 150
X-Ratelimit-Remaining: 48
X-Ratelimit-Replenish-Rate: 100
X-Ratelimit-Requested-Tokens: 1
X-Xss-Protection: 0
```

```
Method parameter 'startDate': Failed to convert value of type 'java.lang.String' to required type 'java.time.ZonedDateTime'; Failed to convert from type [java.lang.String] to type [org.springframework.web.bind.annotation.RequestParam @org.springframework.format.annotation.DateTimeFormat @io.swagger.v3.oas.annotations.Parameter java.time.ZonedDateTime] for value [voluptate]
```

Remediation

Remove 'unsafe-inline' and 'unsafe-eval' from your CSP and use nonces or hashes instead.

Improper Input Validation (Missing Parameter Max Length (Unbounded))

Severity:

MEDIUM

Base CVSS Score:

5.3

CWE: CWE_20

CAPEC Reference: CAPEC-3

OWASP: A05:2025 - Injection

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint:

GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/activity-canvas/{modelId}/appointments

Description

Parameter 'startDate' lacks a maxLength constraint. An abnormally large string (50 KB) was accepted, potential DoS.

Evidence

The server responded with 503 SERVICE_UNAVAILABLE instead of enforcing the schema constraint (should be 400).

Request:

```
GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/activity-canvas/54/appointments?excludePending=true
&size=97&endDate=minus&startDate=AAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAA
AAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAA...[TRUNCATED]
```

Response:

```
Status: 503 SERVICE_UNAVAILABLE

Error: recvAddress(..) failed with error(-104): Connection reset by peer
```

Remediation

Ensure that all incoming data is strictly validated against the defined OpenAPI schema constraints (types, lengths, required fields) using a validation middleware before processing.

Improper Input Validation (Missing Parameter Max Length (Unbounded))

Severity:

MEDIUM

Base CVSS Score:

5.3

CWE: CWE_20

CAPEC Reference: CAPEC-3

OWASP: A05:2025 - Injection

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint:

GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/activity-canvas/{modelId}/appointments

Description

Parameter 'endDate' lacks a maxLength constraint. An abnormally large string (50 KB) was accepted, potential DoS.

Evidence

The server responded with 503 SERVICE_UNAVAILABLE instead of enforcing the schema constraint (should be 400).

Request:

```
GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/activity-canvas/54/appointments?excludePending=true
&size=97&endDate=AAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAA
AAAAAAAAAAAAAAAAAAAA...[TRUNCATED]&startDate=voluptate
```

Response:

```
Status: 503 SERVICE_UNAVAILABLE

Error: recvAddress(..) failed with error(-104): Connection reset by peer
```

Remediation

Ensure that all incoming data is strictly validated against the defined OpenAPI schema constraints (types, lengths, required fields) using a validation middleware before processing.

Reflected Cross-Site Scripting (XSS)

Severity:

MEDIUM

Base CVSS Score:

6.1

CWE: CWE_79

CAPEC Reference: CAPEC-63

OWASP: A05:2025 - Injection

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint:

GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/activity-canvas/{modelId}/appointments

Description

The endpoint reflects unencoded user input from Query Parameter 'size' into the response.

Evidence

Response contains the exact unencoded XSS payload. The response is not HTML, so the script won't execute directly in modern browsers, but could be dangerous if a frontend incorrectly inserts this JSON data into the DOM.

Request:

```
GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/activity-canvas/54/appointments?
excludePending=true&size=<script>alert('XSS_VULNAPI_TEST')<
/script>&endDate=minus&startDate=voluptate
```

Response:

```
Status: 400 BAD_REQUEST
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Content-Length: 176
Content-Security-Policy: default-src 'self' https;; font-src 'self' https: data;; img-src 'self'
https: data;; object-src 'none'; script-src https;; style-src 'self' https: 'unsafe-inline'
Content-Type: text/plain; charset=UTF-8
Date: Sat, 06 Jun 2026 13:23:33 GMT
Expires: 0
Pragma: no-cache
Referrer-Policy: no-referrer
Strict-Transport-Security: max-age=631138519
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
X-Content-Type-Options: nosniff
X-Correlation-Id: 60140004b5045de2af6f53c9e566feb0
X-Download-Options: noopen
X-Frame-Options: DENY
X-Permitted-Cross-Domain-Policies: none
X-Ratelimit-Burst-Capacity: 150
X-Ratelimit-Remaining: 46
X-Ratelimit-Replenish-Rate: 100
X-Ratelimit-Requested-Tokens: 1
X-Xss-Protection: 0

Method parameter 'size': Failed to convert value of type 'java.lang.String' to required type 'java.
lang.Integer'; For input string: "<script>alert('XSS_VULNAPI_TEST')</script>"
```

Remediation

Contextually encode user input before reflecting it in responses. Ensure the Content-Type header is strictly set to application/json for APIs.

Verbose Error Information Leak

Severity:

MEDIUM

Base CVSS Score:

5.3

CWE:

CWE_209

CAPEC Reference:

CAPEC-54

OWASP:

A02:2025 - Security Misconfiguration

Attack Vector:

API Endpoint (Network)

Technical Impact:

Unauthorized Access / Data Exposure

Endpoint:

GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/activity-canvas/{modelId}/appointments

Description

The endpoint returns detailed error messages or stack traces when processing invalid input.

Evidence

Response contains stack traces or framework-specific internal errors after sending malformed or type-mismatched query parameters.

Request:

```
GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/activity-canvas/54/appointments?
size=not_a_number_'["[]{}&endDate=minus%00%ff'"&excludePending=true%00%ff'"&startDate=voluptate%00%
ff'"
```

Response:

```
Status: 400 BAD_REQUEST
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Content-Length: 153
Content-Security-Policy: default-src 'self' https;; font-src 'self' https: data:; img-src 'self'
https: data:; object-src 'none'; script-src https;; style-src 'self' https: 'unsafe-inline'
Content-Type: text/plain;charset=UTF-8
Date: Sat, 06 Jun 2026 13:23:33 GMT
Expires: 0
Pragma: no-cache
Referrer-Policy: no-referrer
Strict-Transport-Security: max-age=631138519
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
X-Content-Type-Options: nosniff
X-Correlation-Id: e8e75ef59972ca7d913ff04e08b39713
X-Download-Options: noopen
X-Frame-Options: DENY
X-Permitted-Cross-Domain-Policies: none
X-Ratelimit-Burst-Capacity: 150
X-Ratelimit-Remaining: 43
X-Ratelimit-Replenish-Rate: 100
X-Ratelimit-Requested-Tokens: 1
X-Xss-Protection: 0

Method parameter 'size': Failed to convert value of type 'java.lang.String' to required type 'java.
lang.Integer'; For input string: "not_a_number_'["[]{}"
```

Remediation

Configure your framework to return generic error messages to the client. Log detailed errors internally only.

Weak Security Header: CSP

Severity:

MEDIUM

Base CVSS Score:
5.4

CWE: CWE_693
CAPEC Reference: CAPEC-63
OWASP: A02:2025 - Security Misconfiguration
Attack Vector: API Endpoint (Network)
Technical Impact: Unauthorized Access / Data Exposure

Endpoint: GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/{participantType}

Description

The Content-Security-Policy header contains 'unsafe-inline' or 'unsafe-eval', which significantly reduces the protection against XSS attacks.

Evidence

CSP value contains unsafe directives: default-src 'self' https;; font-src 'self' https: data;; img-src 'self' https: data;; object-src 'none'; script-src https;; style-src 'self' https: 'unsafe-inline'

Request:

```
GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/voluptatum?singlePatient=true&appointmentType=null&size=92&start=similique&excludePending=true&removeCancelled=true&end=aut&page=6&excludeWithoutPatient=true&medicalServiceId=32&participantActorIds=temporibus&status=minima
```

Response:

```
Status: 400 BAD_REQUEST
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Content-Length: 383
Content-Security-Policy: default-src 'self' https;; font-src 'self' https: data;; img-src 'self' https: data;; object-src 'none'; script-src https;; style-src 'self' https: 'unsafe-inline'
Content-Type: text/plain; charset=UTF-8
Date: Sat, 06 Jun 2026 13:23:33 GMT
Expires: 0
Pragma: no-cache
Referrer-Policy: no-referrer
Strict-Transport-Security: max-age=631138519
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
X-Content-Type-Options: nosniff
X-Correlation-Id: 9a4072ac471210c179f7295f630eba14
X-Download-Options: noopen
X-Frame-Options: DENY
X-Permitted-Cross-Domain-Policies: none
X-Ratelimit-Burst-Capacity: 150
X-Ratelimit-Remaining: 33
X-Ratelimit-Replenish-Rate: 100
X-Ratelimit-Requested-Tokens: 1
X-Xss-Protection: 0
```

```
Method parameter 'participantType': Failed to convert value of type 'java.lang.String' to required type 'ch.hcuge.service.appointment.enums.ParticipantType'; Failed to convert from type [java.lang.String] to type [@org.springframework.web.bind.annotation.PathVariable @io.swagger.v3.oas.annotations.Parameter ch.hcuge.service.appointment.enums.ParticipantType] for value [voluptatum]
```

Remediation

Remove 'unsafe-inline' and 'unsafe-eval' from your CSP and use nonces or hashes instead.

Verbose Error Information Leak

Severity:

MEDIUM

Base CVSS Score:
5.3

CWE: CWE_209
CAPEC Reference: CAPEC-54
OWASP: A02:2025 - Security Misconfiguration
Attack Vector: API Endpoint (Network)
Technical Impact: Unauthorized Access / Data Exposure

Endpoint: GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/{participantType}

Description

The endpoint returns detailed error messages or stack traces when processing invalid input.

Evidence

Response contains stack traces or framework-specific internal errors after sending malformed or type-mismatched query parameters.

Request:

```
GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/voluptatum?singlePatient=true%00%ff'"&appointmentType=nulla%00%ff'"&size=not_a_number_'[]"{}&start=similique%00%ff'"&excludePending=true%00%ff'"&removeCancelled=true%00%ff'"&end=aut%00%ff'"&page=not_a_number_'[]"{}&excludeWithoutPatient=true%00%ff'"&medicalServiceId=not_a_number_'[]"{}&participantActorIds=temporibus%00%ff'"&status=minima%00%ff'"
```

Response:

```
Status: 400 BAD_REQUEST
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Content-Length: 383
Content-Security-Policy: default-src 'self' https;; font-src 'self' https: data;; img-src 'self' https: data;; object-src 'none'; script-src https;; style-src 'self' https: 'unsafe-inline'
Content-Type: text/plain;charset=UTF-8
Date: Sat, 06 Jun 2026 13:23:34 GMT
Expires: 0
Pragma: no-cache
Referrer-Policy: no-referrer
Strict-Transport-Security: max-age=631138519
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
X-Content-Type-Options: nosniff
X-Correlation-Id: d830f62de3dfb03f4e6242e52541153e
X-Download-Options: noopen
X-Frame-Options: DENY
X-Permitted-Cross-Domain-Policies: none
X-Ratelimit-Burst-Capacity: 150
X-Ratelimit-Remaining: 98
X-Ratelimit-Replenish-Rate: 100
X-Ratelimit-Requested-Tokens: 1
X-Xss-Protection: 0

Method parameter 'participantType': Failed to convert value of type 'java.lang.String' to required type 'ch.hcuge.service.appointment.enums.ParticipantType'; Failed to convert from type [java.lang.String] to type [@org.springframework.web.bind.annotation.PathVariable @io.swagger.v3.oas.annotations.Parameter ch.hcuge.service.appointment.enums.ParticipantType] for value [voluptatum]
```

Remediation

Configure your framework to return generic error messages to the client. Log detailed errors internally only.

Weak Security Header: CSP

Severity:

MEDIUM

Base CVSS Score:

5.4

CWE:

CWE_693

CAPEC Reference:

CAPEC-63

OWASP:

A02:2025 - Security Misconfiguration

Attack Vector:

API Endpoint (Network)

Technical Impact:

Unauthorized Access / Data Exposure

Endpoint:

GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/{id}/history

Description

The Content-Security-Policy header contains 'unsafe-inline' or 'unsafe-eval', which significantly reduces the protection against XSS attacks.

Evidence

CSP value contains unsafe directives: default-src 'self' https;; font-src 'self' https: data;; img-src 'self' https: data;; object-src 'none'; script-src https;; style-src 'self' https: 'unsafe-inline'

Request:

```
GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/67/history?operationTypes=nostrum
```

Response:

```
Status: 400 BAD_REQUEST
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Content-Length: 339
Content-Security-Policy: default-src 'self' https;; font-src 'self' https: data;; img-src 'self' https: data;; object-src 'none'; script-src https;; style-src 'self' https: 'unsafe-inline'
Content-Type: text/plain;charset=UTF-8
Date: Sat, 06 Jun 2026 13:23:34 GMT
Expires: 0
Pragma: no-cache
Referrer-Policy: no-referrer
Strict-Transport-Security: max-age=631138519
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
X-Content-Type-Options: nosniff
X-Correlation-Id: 100469213f98c9de32a713b4baada405
X-Download-Options: noopen
X-Frame-Options: DENY
X-Permitted-Cross-Domain-Policies: none
X-Ratelimit-Burst-Capacity: 150
X-Ratelimit-Remaining: 92
X-Ratelimit-Replenish-Rate: 100
X-Ratelimit-Requested-Tokens: 1
X-Xss-Protection: 0

Method parameter 'operationTypes': Failed to convert value of type 'java.lang.String' to required type 'java.util.List'; Failed to convert from type [java.lang.String] to type [@org.springframework.web.bind.annotation.RequestParam @io.swagger.v3.oas.annotations.Parameter ch.hcuge.service.appointment.enums.HistoryType] for value [nostrum]
```

Remediation

Remove 'unsafe-inline' and 'unsafe-eval' from your CSP and use nonces or hashes instead.

Reflected Cross-Site Scripting (XSS)

Severity:

MEDIUM

Base CVSS Score:
6.1

CWE: CWE_79
CAPEC Reference: CAPEC-63
OWASP: A05:2025 - Injection
Attack Vector: API Endpoint (Network)
Technical Impact: Unauthorized Access / Data Exposure

Endpoint: GET <https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/{id}/history>

Description

The endpoint reflects unencoded user input from Query Parameter 'operationTypes' into the response.

Evidence

Response contains the exact unencoded XSS payload. The response is not HTML, so the script won't execute directly in modern browsers, but could be dangerous if a frontend incorrectly inserts this JSON data into the DOM.

Request:

```
GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/67/history?
operationTypes=<script>alert('XSS_VULNAPI_TEST')</script>
```

Response:

```
Status: 400 BAD_REQUEST
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Content-Length: 374
Content-Security-Policy: default-src 'self' https;; font-src 'self' https: data;; img-src 'self'
https: data;; object-src 'none'; script-src https;; style-src 'self' https: 'unsafe-inline'
Content-Type: text/plain;charset=UTF-8
Date: Sat, 06 Jun 2026 13:23:34 GMT
Expires: 0
Pragma: no-cache
Referrer-Policy: no-referrer
Strict-Transport-Security: max-age=631138519
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
X-Content-Type-Options: nosniff
X-Correlation-Id: 8a9c6b56142399fc03d93973101c7f9a
X-Download-Options: noopen
X-Frame-Options: DENY
X-Permitted-Cross-Domain-Policies: none
X-Ratelimit-Burst-Capacity: 150
X-Ratelimit-Remaining: 90
X-Ratelimit-Replenish-Rate: 100
X-Ratelimit-Requested-Tokens: 1
X-Xss-Protection: 0

Method parameter 'operationTypes': Failed to convert value of type 'java.lang.String' to required
type 'java.util.List'; Failed to convert from type [java.lang.String] to type [@org.springframework.
web.bind.annotation.RequestParam @io.swagger.v3.oas.annotations.Parameter ch.hcuge.service.
appointment.enums.HistoryType] for value [<script>alert('XSS_VULNAPI_TEST')</script>]
```

Remediation

Contextually encode user input before reflecting it in responses. Ensure the Content-Type header is strictly set to application/json for APIs.

Improper Input Validation (Missing Parameter Max Length (Unbounded))

Severity:

MEDIUM

Base CVSS Score:
5.3

CWE: CWE_20
CAPEC Reference: CAPEC-3
OWASP: A05:2025 - Injection
Attack Vector: API Endpoint (Network)
Technical Impact: Unauthorized Access / Data Exposure

Endpoint: GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/{id}/history

Description

Parameter 'operationTypes' lacks a maxLength constraint. An abnormally large string (50 KB) was accepted, potential DoS.

Evidence

The server responded with 503 SERVICE_UNAVAILABLE instead of enforcing the schema constraint (should be 400).

Request:

```
GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/67/history?operationTypes=AAAAAAAAAAAA
AAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAA...
[TRUNCATED]
```

Response:

```
Status: 503 SERVICE_UNAVAILABLE

Error: recvAddress(..) failed with error(-104): Connection reset by peer
```

Remediation

Ensure that all incoming data is strictly validated against the defined OpenAPI schema constraints (types, lengths, required fields) using a validation middleware before processing.

Verbose Error Information Leak

Severity:

MEDIUM

Base CVSS Score:
5.3

CWE: CWE_209
CAPEC Reference: CAPEC-54
OWASP: A02:2025 - Security Misconfiguration
Attack Vector: API Endpoint (Network)
Technical Impact: Unauthorized Access / Data Exposure

Endpoint: GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/{id}/history

Description

The endpoint returns detailed error messages or stack traces when processing invalid input.

Evidence

Response contains stack traces or framework-specific internal errors after sending malformed or type-mismatched query parameters.

Request:

```
GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/67/history?operationTypes=nostrum%00%ff'"
```

Response:

```
Status: 400 BAD_REQUEST
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Content-Length: 347
Content-Security-Policy: default-src 'self' https;; font-src 'self' https: data;; img-src 'self' https: data;; object-src 'none'; script-src https;; style-src 'self' https: 'unsafe-inline'
Content-Type: text/plain;charset=UTF-8
Date: Sat, 06 Jun 2026 13:23:34 GMT
Expires: 0
Pragma: no-cache
Referrer-Policy: no-referrer
Strict-Transport-Security: max-age=631138519
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
X-Content-Type-Options: nosniff
X-Correlation-Id: b28aa9f962d5905a33cce531ec2f319e
X-Download-Options: noopen
X-Frame-Options: DENY
X-Permitted-Cross-Domain-Policies: none
X-Ratelimit-Burst-Capacity: 150
X-Ratelimit-Remaining: 82
X-Ratelimit-Replenish-Rate: 100
X-Ratelimit-Requested-Tokens: 1
X-Xss-Protection: 0

Method parameter 'operationTypes': Failed to convert value of type 'java.lang.String' to required type 'java.util.List'; Failed to convert from type [java.lang.String] to type [@org.springframework.web.bind.annotation.RequestParam @io.swagger.v3.oas.annotations.Parameter ch.hcuge.service.appointment.enums.HistoryType] for value [nostrum%00%ff']"
```

Remediation

Configure your framework to return generic error messages to the client. Log detailed errors internally only.

Improper Input Validation (Missing Parameter Max Length (Unbounded))

Severity:

MEDIUM

Base CVSS Score:

5.3

CWE: CWE_20

CAPEC Reference: CAPEC-3

OWASP: A05:2025 - Injection

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: GET <https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/{participantType}>

Description

Parameter 'participantType' lacks a maxLength constraint. An abnormally large string (50 KB) was accepted, potential DoS.

Evidence

The server responded with 503 SERVICE_UNAVAILABLE instead of enforcing the schema constraint (should be 400).

Request:

```
GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/A AAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAA  
AAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAA  
AAAA...[TRUNCATED]?singlePatient=true&appointmentType=null&size=92&start=similique&excludePending=t  
rue&removeCancelled=true&end=aut&page=6&excludeWithoutPatient=true&medicalServiceId=32&participantAc  
torIds=temporibus&status=minima
```

Response:

Status: 503 SERVICE_UNAVAILABLE

```
Error: recvAddress(..) failed with error(-104): Connection reset by peer
```

Remediation

Ensure that all incoming data is strictly validated against the defined OpenAPI schema constraints (types, lengths, required fields) using a validation middleware before processing.

Improper Input Validation (Missing Parameter Max Length (Unbounded))

Severity:

MEDIUM

Base CVSS Score:

5.3

CWE: CWE_20

CAPEC Reference: CAPEC-3

OWASP: A05:2025 - Injection

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: GET <https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/{participantType}>

Description

Parameter 'appointmentType' lacks a maxLength constraint. An abnormally large string (50 KB) was accepted, potential DoS.

Evidence

The server responded with 503 SERVICE_UNAVAILABLE instead of enforcing the schema constraint (should be 400).

Request:

GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/voluptatum?singlePatient=true&appointm
entType=AA
AAAAAAAA... [TRUNCATED]&size=92&start=similique&excludePending=true&removeCancelled=true&end=aut&page
=6&excludeWithoutPatient=true&medicalServiceId=32&participantActorIds=temporibus&status=minima

Response:

Status: 503 SERVICE_UNAVAILABLE

```
Error: recvAddress(..) failed with error(-104): Connection reset by peer
```

Remediation

Ensure that all incoming data is strictly validated against the defined OpenAPI schema constraints (types, lengths, required fields) using a validation middleware before processing.

Improper Input Validation (Missing Parameter Max Length (Unbounded))

Severity:

MEDIUM

Base CVSS Score:

5.3

CWE: CWE_20

CAPEC Reference: CAPEC-3

OWASP: A05:2025 - Injection

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: GET <https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/{participantType}>

Description

Parameter 'participantActorIds' lacks a maxLength constraint. An abnormally large string (50 KB) was accepted, potential DoS.

Evidence

The server responded with 503 SERVICE_UNAVAILABLE instead of enforcing the schema constraint (should be 400).

Request:

[illegible]

Response:

Status: 503 SERVICE_UNAVAILABLE

```
Error: recvAddress(..) failed with error(-104): Connection reset by peer
```

Remediation

Ensure that all incoming data is strictly validated against the defined OpenAPI schema constraints (types, lengths, required fields) using a validation middleware before processing.

Improper Input Validation (Missing Parameter Max Length (Unbounded))

Severity:

MEDIUM

Base CVSS Score:

5.3

CWE: CWE_20

CAPEC Reference: CAPEC-3

OWASP: A05:2025 - Injection

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/{participantType}

Description

Parameter 'start' lacks a maxLength constraint. An abnormally large string (50 KB) was accepted, potential DoS.

Evidence

The server responded with 503 SERVICE_UNAVAILABLE instead of enforcing the schema constraint (should be 400).

Request:

```
GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/voluptatum?singlePatient=true&appointm
entType=null&size=92&start=AAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAA
AAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAA
AAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAA
...[TRUNCATED]&excludePending=true&removeCancelled=true&end=aut&page=6&e
xcludeWithoutPatient=true&medicalServiceId=32&participantActorIds=temporibus&status=minima
```

Response:

```
Status: 503 SERVICE_UNAVAILABLE

Error: recvAddress(..) failed with error(-104): Connection reset by peer
```

Remediation

Ensure that all incoming data is strictly validated against the defined OpenAPI schema constraints (types, lengths, required fields) using a validation middleware before processing.

Improper Input Validation (Missing Parameter Max Length (Unbounded))

Severity:

MEDIUM

Base CVSS Score:

5.3

CWE:

CWE_20

CAPEC Reference:

CAPEC-3

OWASP:

A05:2025 - Injection

Attack Vector:

API Endpoint (Network)

Technical Impact:

Unauthorized Access / Data Exposure

Endpoint: GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/{participantType}

Description

Parameter 'end' lacks a maxLength constraint. An abnormally large string (50 KB) was accepted, potential DoS.

Evidence

The server responded with 503 SERVICE_UNAVAILABLE instead of enforcing the schema constraint (should be 400).

Request:

```
GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/voluptatum?singlePatient=true&appointm
entType=null&size=92&start=similique&excludePending=true&removeCancelled=true&end=AAAAAAAAAAAAAAAA
AAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAA...[TRUNCATED]
&page=6&excludeWithoutPatient=true&medicalServiceId=32&participantActorIds=temporibus&status=minima
```

Response:

```
Status: 503 SERVICE_UNAVAILABLE

Error: recvAddress(..) failed with error(-104): Connection reset by peer
```

Remediation

Ensure that all incoming data is strictly validated against the defined OpenAPI schema constraints (types, lengths, required fields) using a validation middleware before processing.

Missing Rate Limiting

Severity:

MEDIUM

Base CVSS Score:

5.3

CWE: CWE_799

CAPEC Reference: CAPEC-115

OWASP: A06:2025 - Insecure Design

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: PATCH <https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/{appointmentId}/patients/{patientId}/status-and-encounter> [TRUNCATED]

Description

The endpoint does not seem to enforce rate limiting. 50 rapid requests were sent without receiving a 429 Too Many Requests response.

Evidence

After 50 requests, the server returned status 400 instead of 429.

Request:

```
PATCH https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/11/patients/98/status-and-encounter
Content-Type: application/json
```

```
{"data": "officiis"}
```

Response:

No Response

Remediation

Implement rate limiting using a gateway, WAF, or application logic (e.g. token bucket algorithm).

Weak Security Header: HSTS

Severity:

LOW

Base CVSS Score:

4.3

CWE: CWE_693

CAPEC Reference: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: PATCH <https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/{id}>

Description

The Strict-Transport-Security (HSTS) header is present but misconfigured (missing max-age or includeSubDomains).

Evidence

HSTS value is misconfigured: max-age=631138519

Request:

```
PATCH https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/7?
recurrenceUpdateOption=non&autoVisit=true
Content-Type: application/json

{"data": "iusto"}
```

Response:

```
Status: 400 BAD_REQUEST
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Content-Length: 399
Content-Security-Policy: default-src 'self' https;; font-src 'self' https: data;; img-src 'self'
https: data;; object-src 'none'; script-src https;; style-src 'self' https: 'unsafe-inline'
Content-Type: text/plain;charset=UTF-8
Date: Sat, 06 Jun 2026 13:23:02 GMT
Expires: 0
Pragma: no-cache
Referrer-Policy: no-referrer
Strict-Transport-Security: max-age=631138519
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
X-Content-Type-Options: nosniff
X-Correlation-Id: c76421054de5f487cdb9913ddecdb977
X-Download-Options: noopen
X-Frame-Options: DENY
X-Permitted-Cross-Domain-Policies: none
X-Ratelimit-Burst-Capacity: 150
X-Ratelimit-Remaining: 105
X-Ratelimit-Replenish-Rate: 100
X-Ratelimit-Requested-Tokens: 1
X-Xss-Protection: 0

Method parameter 'recurrenceUpdateOption': Failed to convert value of type 'java.lang.String' to
required type 'ch.hcuge.service.appointment.enums.PeriodicityUpdateOption'; Failed to convert from
type [java.lang.String] to type [@org.springframework.web.bind.annotation.RequestParam @io.swagger.
v3.oas.annotations.Parameter ch.hcuge.service.appointment.enums.PeriodicityUpdateOption] for value
[non]
```

Remediation

Ensure HSTS has a large max-age (e.g., 31536000) and includes 'includeSubDomains'.

Missing Security Header: Permissions-Policy

Severity:

LOW

Base CVSS Score: 4.3

CWE: CWE_693
CAPEC Reference: CAPEC-310
OWASP: A02:2025 - Security Misconfiguration
Attack Vector: API Endpoint (Network)
Technical Impact: Unauthorized Access / Data Exposure

Endpoint: PATCH https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/{id}

Description

The HTTP response does not contain the 'Permissions-Policy' security header.

Evidence

Header 'Permissions-Policy' is missing from the response.

Request:

```
PATCH https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/7?
recurrenceUpdateOption=non&autoVisit=true
Content-Type: application/json

{"data": "iusto"}
```

Response:

```
Status: 400 BAD_REQUEST
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Content-Length: 399
Content-Security-Policy: default-src 'self' https;; font-src 'self' https: data:; img-src 'self'
https: data:; object-src 'none'; script-src https;; style-src 'self' https: 'unsafe-inline'
Content-Type: text/plain;charset=UTF-8
Date: Sat, 06 Jun 2026 13:23:02 GMT
Expires: 0
Pragma: no-cache
Referrer-Policy: no-referrer
Strict-Transport-Security: max-age=631138519
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
X-Content-Type-Options: nosniff
X-Correlation-Id: c76421054de5f487cdb9913ddecdbd977
X-Download-Options: noopen
X-Frame-Options: DENY
X-Permitted-Cross-Domain-Policies: none
X-Ratelimit-Burst-Capacity: 150
X-Ratelimit-Remaining: 105
X-Ratelimit-Replenish-Rate: 100
X-Ratelimit-Requested-Tokens: 1
X-Xss-Protection: 0

Method parameter 'recurrenceUpdateOption': Failed to convert value of type 'java.lang.String' to
required type 'ch.hcuge.service.appointment.enums.PeriodicityUpdateOption'; Failed to convert from
type [java.lang.String] to type [@org.springframework.web.bind.annotation.RequestParam @io.swagger.
v3.oas.annotations.Parameter ch.hcuge.service.appointment.enums.PeriodicityUpdateOption] for value
[non]
```

Remediation

Configure your web server or application framework to include the 'Permissions-Policy' header in all responses.

Unexpected Content-Type (Parameter Type Violation)

Severity:

LOW

Base CVSS Score:

3.7

CWE:

CWE_20

CAPEC Reference:

CAPEC-3

OWASP:

A05:2025 - Injection

Attack Vector:

API Endpoint (Network)

Technical Impact:

Unauthorized Access / Data Exposure

Endpoint: PUT <https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/{id}>

Description

The API responded with an undocumented Content-Type ('text/plain;charset=UTF-8') instead of the expected format(s): [application/json]. This often indicates an unhandled exception or bypass of the framework's standard error handler.

Evidence

Response Content-Type is: text/plain;charset=UTF-8

Request:

```
PUT https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/invalid_string_not_number?
recurrenceUpdateOption=maiores&autoVisit=true
Content-Type: application/json

{"data": "voluptas"}
```

Response:

```
Status: 400 BAD_REQUEST
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Content-Length: 154
Content-Security-Policy: default-src 'self' https;; font-src 'self' https: data;; img-src 'self'
https: data;; object-src 'none'; script-src https;; style-src 'self' https: 'unsafe-inline'
Content-Type: text/plain;charset=UTF-8
Date: Sat, 06 Jun 2026 13:23:02 GMT
Expires: 0
Pragma: no-cache
Referrer-Policy: no-referrer
Strict-Transport-Security: max-age=631138519
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
X-Content-Type-Options: nosniff
X-Correlation-Id: 90b4788f977d1e256fa533fbfd46b806
X-Download-Options: noopen
X-Frame-Options: DENY
X-Permitted-Cross-Domain-Policies: none
X-Ratelimit-Burst-Capacity: 150
X-Ratelimit-Remaining: 133
X-Ratelimit-Replenish-Rate: 100
X-Ratelimit-Requested-Tokens: 1
X-Xss-Protection: 0
```

```
Method parameter 'id': Failed to convert value of type 'java.lang.String' to required type 'java.
lang.Long'; For input string: "invalid_string_not_number"
```

Remediation

Ensure that all API responses, including error messages (4xx/5xx), conform to the expected Content-Type (e. g., application/json). Check exception handlers to avoid returning raw text.

Unexpected Content-Type (Parameter Enum Violation)

Severity:

LOW

Base CVSS Score:
3.7

CWE: CWE_20
CAPEC Reference: CAPEC-3
OWASP: A05:2025 - Injection
Attack Vector: API Endpoint (Network)
Technical Impact: Unauthorized Access / Data Exposure

Endpoint: PUT <https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/{id}>

Description

The API responded with an undocumented Content-Type ('text/plain;charset=UTF-8') instead of the expected format(s): [application/json]. This often indicates an unhandled exception or bypass of the framework's standard error handler.

Evidence

Response Content-Type is: text/plain;charset=UTF-8

Request:

```
PUT https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/37?
recurrenceUpdateOption=ORTHRUS_INVALID_ENUM&autoVisit=true
Content-Type: application/json

{"data": "voluptas"}
```

Response:

```
Status: 400 BAD_REQUEST
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Content-Length: 416
Content-Security-Policy: default-src 'self' https;; font-src 'self' https: data;; img-src 'self' https: data;; object-src 'none'; script-src https;; style-src 'self' https: 'unsafe-inline'
Content-Type: text/plain;charset=UTF-8
Date: Sat, 06 Jun 2026 13:23:02 GMT
Expires: 0
Pragma: no-cache
Referrer-Policy: no-referrer
Strict-Transport-Security: max-age=631138519
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
X-Content-Type-Options: nosniff
X-Correlation-Id: 0ba5a93338e1f0e161ce62275ef0a139
X-Download-Options: noopen
X-Frame-Options: DENY
X-Permitted-Cross-Domain-Policies: none
X-Ratelimit-Burst-Capacity: 150
X-Ratelimit-Remaining: 104
X-Ratelimit-Replenish-Rate: 100
X-Ratelimit-Requested-Tokens: 1
X-Xss-Protection: 0

Method parameter 'recurrenceUpdateOption': Failed to convert value of type 'java.lang.String' to required type 'ch.hcuge.service.appointment.enums.PeriodicityUpdateOption'; Failed to convert from type [java.lang.String] to type [@org.springframework.web.bind.annotation.RequestParam @io.swagger.v3.oas.annotations.Parameter ch.hcuge.service.appointment.enums.PeriodicityUpdateOption] for value [ORTHURUS_INVALID_ENUM]
```

Remediation

Ensure that all API responses, including error messages (4xx/5xx), conform to the expected Content-Type (e.g., application/json). Check exception handlers to avoid returning raw text.

Unexpected Content-Type (Parameter Type Violation)

Severity:

LOW

Base CVSS Score:
3.7

CWE: CWE_20
CAPEC Reference: CAPEC-3
OWASP: A05:2025 - Injection
Attack Vector: API Endpoint (Network)
Technical Impact: Unauthorized Access / Data Exposure

Endpoint: PATCH `https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/{id}`

Description

The API responded with an undocumented Content-Type ('text/plain;charset=UTF-8') instead of the expected format(s): [application/json]. This often indicates an unhandled exception or bypass of the framework's standard error handler.

Evidence

Response Content-Type is: text/plain;charset=UTF-8

Request:

```
PATCH https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/invalid_string_not_number?
recurrenceUpdateOption=non&autoVisit=true
Content-Type: application/json

{"data": "iusto"}
```

Response:

```
Status: 400 BAD_REQUEST
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Content-Length: 154
Content-Security-Policy: default-src 'self' https;; font-src 'self' https: data;; img-src 'self'
https: data;; object-src 'none'; script-src https;; style-src 'self' https: 'unsafe-inline'
Content-Type: text/plain;charset=UTF-8
Date: Sat, 06 Jun 2026 13:23:02 GMT
Expires: 0
Pragma: no-cache
Referrer-Policy: no-referrer
Strict-Transport-Security: max-age=631138519
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
X-Content-Type-Options: nosniff
X-Correlation-Id: 44b68eb0416a9ca13575a7cef37730f7
X-Download-Options: noopen
X-Frame-Options: DENY
X-Permitted-Cross-Domain-Policies: none
X-Ratelimit-Burst-Capacity: 150
X-Ratelimit-Remaining: 70
X-Ratelimit-Replenish-Rate: 100
X-Ratelimit-Requested-Tokens: 1
X-Xss-Protection: 0
```

```
Method parameter 'id': Failed to convert value of type 'java.lang.String' to required type 'java.
lang.Long'; For input string: "invalid_string_not_number"
```

Remediation

Ensure that all API responses, including error messages (4xx/5xx), conform to the expected Content-Type (e. g., application/json). Check exception handlers to avoid returning raw text.

Unexpected Content-Type (Parameter Enum Violation)

Severity:

LOW

Base CVSS Score:
3.7

CWE: CWE_20
CAPEC Reference: CAPEC-3
OWASP: A05:2025 - Injection
Attack Vector: API Endpoint (Network)
Technical Impact: Unauthorized Access / Data Exposure

Endpoint: PATCH `https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/{id}`

Description

The API responded with an undocumented Content-Type ('text/plain;charset=UTF-8') instead of the expected format(s): [application/json]. This often indicates an unhandled exception or bypass of the framework's standard error handler.

Evidence

Response Content-Type is: text/plain;charset=UTF-8

Request:

```
PATCH https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/7?
recurrenceUpdateOption=ORTHRUS_INVALID_ENUM&autoVisit=true
Content-Type: application/json

{"data": "iusto"}
```

Response:

```
Status: 400 BAD_REQUEST
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Content-Length: 416
Content-Security-Policy: default-src 'self' https;; font-src 'self' https: data;; img-src 'self' https: data;; object-src 'none'; script-src https;; style-src 'self' https: 'unsafe-inline'
Content-Type: text/plain;charset=UTF-8
Date: Sat, 06 Jun 2026 13:23:02 GMT
Expires: 0
Pragma: no-cache
Referrer-Policy: no-referrer
Strict-Transport-Security: max-age=631138519
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
X-Content-Type-Options: nosniff
X-Correlation-Id: 2d1b6614441077712e6db323e9118a61
X-Download-Options: noopen
X-Frame-Options: DENY
X-Permitted-Cross-Domain-Policies: none
X-Ratelimit-Burst-Capacity: 150
X-Ratelimit-Remaining: 74
X-Ratelimit-Replenish-Rate: 100
X-Ratelimit-Requested-Tokens: 1
X-Xss-Protection: 0

Method parameter 'recurrenceUpdateOption': Failed to convert value of type 'java.lang.String' to required type 'ch.hcuge.service.appointment.enums.PeriodicityUpdateOption'; Failed to convert from type [java.lang.String] to type [@org.springframework.web.bind.annotation.RequestParam @io.swagger.v3.oas.annotations.Parameter ch.hcuge.service.appointment.enums.PeriodicityUpdateOption] for value [ORTHUS_INVALID_ENUM]
```

Remediation

Ensure that all API responses, including error messages (4xx/5xx), conform to the expected Content-Type (e.g., application/json). Check exception handlers to avoid returning raw text.

Weak Security Header: HSTS

Severity:

LOW

Base CVSS Score:

4.3

CWE: CWE_693

CAPEC Reference: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: PUT <https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/{id}>

Description

The Strict-Transport-Security (HSTS) header is present but misconfigured (missing max-age or includeSubDomains).

Evidence

HSTS value is misconfigured: max-age=631138519

Request:

```
PUT https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/37?
recurrenceUpdateOption=maiores&autoVisit=true
Content-Type: application/json

{"data": "voluptas"}
```

Response:

```
Status: 400 BAD_REQUEST
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Content-Length: 403
Content-Security-Policy: default-src 'self' https;; font-src 'self' https: data;; img-src 'self'
https: data;; object-src 'none'; script-src https;; style-src 'self' https: 'unsafe-inline'
Content-Type: text/plain;charset=UTF-8
Date: Sat, 06 Jun 2026 13:23:02 GMT
Expires: 0
Pragma: no-cache
Referrer-Policy: no-referrer
Strict-Transport-Security: max-age=631138519
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
X-Content-Type-Options: nosniff
X-Correlation-Id: e6209b27be8b2eeacd49764e3b585aae
X-Download-Options: noopen
X-Frame-Options: DENY
X-Permitted-Cross-Domain-Policies: none
X-Ratelimit-Burst-Capacity: 150
X-Ratelimit-Remaining: 99
X-Ratelimit-Replenish-Rate: 100
X-Ratelimit-Requested-Tokens: 1
X-Xss-Protection: 0

Method parameter 'recurrenceUpdateOption': Failed to convert value of type 'java.lang.String' to
required type 'ch.hcuge.service.appointment.enums.PeriodicityUpdateOption'; Failed to convert from
type [java.lang.String] to type [@org.springframework.web.bind.annotation.RequestParam @io.swagger.
v3.oas.annotations.Parameter ch.hcuge.service.appointment.enums.PeriodicityUpdateOption] for value
[maiores]
```

Remediation

Ensure HSTS has a large max-age (e.g., 31536000) and includes 'includeSubDomains'.

Missing Security Header: Permissions-Policy

Severity:

LOW

Base CVSS Score:

4.3

CWE:

CWE_693

CAPEC Reference:

CAPEC-310

OWASP:

A02:2025 - Security Misconfiguration

Attack Vector:

API Endpoint (Network)

Technical Impact:

Unauthorized Access / Data Exposure

Endpoint:

PUT https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/{id}

Description

The HTTP response does not contain the 'Permissions-Policy' security header.

Evidence

Header 'Permissions-Policy' is missing from the response.

Request:

```
PUT https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/37?
recurrenceUpdateOption=maiores&autoVisit=true
Content-Type: application/json

{"data": "voluptas"}
```

Response:

```
Status: 400 BAD_REQUEST
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Content-Length: 403
Content-Security-Policy: default-src 'self' https;; font-src 'self' https: data:; img-src 'self'
https: data:; object-src 'none'; script-src https;; style-src 'self' https: 'unsafe-inline'
Content-Type: text/plain;charset=UTF-8
Date: Sat, 06 Jun 2026 13:23:02 GMT
Expires: 0
Pragma: no-cache
Referrer-Policy: no-referrer
Strict-Transport-Security: max-age=631138519
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
X-Content-Type-Options: nosniff
X-Correlation-Id: e6209b27be8b2eeacd49764e3b585aae
X-Download-Options: noopen
X-Frame-Options: DENY
X-Permitted-Cross-Domain-Policies: none
X-Ratelimit-Burst-Capacity: 150
X-Ratelimit-Remaining: 99
X-Ratelimit-Replenish-Rate: 100
X-Ratelimit-Requested-Tokens: 1
X-Xss-Protection: 0

Method parameter 'recurrenceUpdateOption': Failed to convert value of type 'java.lang.String' to
required type 'ch.hcuge.service.appointment.enums.PeriodicityUpdateOption'; Failed to convert from
type [java.lang.String] to type [@org.springframework.web.bind.annotation.RequestParam @io.swagger.
v3.oas.annotations.Parameter ch.hcuge.service.appointment.enums.PeriodicityUpdateOption] for value
[maiores]
```

Remediation

Configure your web server or application framework to include the 'Permissions-Policy' header in all responses.

Weak Security Header: HSTS

Severity:

LOW

Base CVSS Score:

4.3

CWE:

CWE_693

CAPEC Reference:

CAPEC-310

OWASP:

A02:2025 - Security Misconfiguration

Attack Vector:

API Endpoint (Network)

Technical Impact:

Unauthorized Access / Data Exposure

Endpoint:

GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/persons/{personId}/appointments

Description

The Strict-Transport-Security (HSTS) header is present but misconfigured (missing max-age or includeSubDomains).

Evidence

HSTS value is misconfigured: max-age=631138519

Request:

```
GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/persons/officia/appointments?
size=37&endDate=architecto&activityModelId=96&startDate=nihil
```

Response:

```
Status: 400 BAD_REQUEST
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Content-Length: 372
Content-Security-Policy: default-src 'self' https;; font-src 'self' https: data;; img-src 'self'
https: data;; object-src 'none'; script-src https;; style-src 'self' https: 'unsafe-inline'
Content-Type: text/plain;charset=UTF-8
Date: Sat, 06 Jun 2026 13:23:02 GMT
Expires: 0
Pragma: no-cache
Referrer-Policy: no-referrer
Strict-Transport-Security: max-age=631138519
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
X-Content-Type-Options: nosniff
X-Correlation-Id: f037589b3e6e108cd799b33dd8acde2b
X-Download-Options: noopen
X-Frame-Options: DENY
X-Permitted-Cross-Domain-Policies: none
X-Ratelimit-Burst-Capacity: 150
X-Ratelimit-Remaining: 31
X-Ratelimit-Replenish-Rate: 100
X-Ratelimit-Requested-Tokens: 1
X-Xss-Protection: 0
```

```
Method parameter 'startDate': Failed to convert value of type 'java.lang.String' to required type
'java.time.ZonedDateTime'; Failed to convert from type [java.lang.String] to type [org.
springframework.web.bind.annotation.RequestParam @org.springframework.format.annotation.
DateTimeFormat @io.swagger.v3.oas.annotations.Parameter java.time.ZonedDateTime] for value [nihil]
```

Remediation

Ensure HSTS has a large max-age (e.g., 31536000) and includes 'includeSubDomains'.

Missing Security Header: Permissions-Policy

Severity:

LOW

Base CVSS Score:

4.3

CWE:

CWE_693

CAPEC Reference:

CAPEC-310

OWASP:

A02:2025 - Security Misconfiguration

Attack Vector:

API Endpoint (Network)

Technical Impact:

Unauthorized Access / Data Exposure

Endpoint: GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/persons/{personId}/appointments

Description

The HTTP response does not contain the 'Permissions-Policy' security header.

Evidence

Header 'Permissions-Policy' is missing from the response.

Request:

```
GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/persons/officiala/appointments?
size=37&endDate=architecto&activityModelId=96&startDate=nihil
```

Response:

```
Status: 400 BAD_REQUEST
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Content-Length: 372
Content-Security-Policy: default-src 'self' https;; font-src 'self' https: data:; img-src 'self'
https: data:; object-src 'none'; script-src https;; style-src 'self' https: 'unsafe-inline'
Content-Type: text/plain;charset=UTF-8
Date: Sat, 06 Jun 2026 13:23:02 GMT
Expires: 0
Pragma: no-cache
Referrer-Policy: no-referrer
Strict-Transport-Security: max-age=631138519
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
X-Content-Type-Options: nosniff
X-Correlation-Id: f037589b3e6e108cd799b33dd8acde2b
X-Download-Options: noopen
X-Frame-Options: DENY
X-Permitted-Cross-Domain-Policies: none
X-Ratelimit-Burst-Capacity: 150
X-Ratelimit-Remaining: 31
X-Ratelimit-Replenish-Rate: 100
X-Ratelimit-Requested-Tokens: 1
X-Xss-Protection: 0

Method parameter 'startDate': Failed to convert value of type 'java.lang.String' to required type
'java.time.ZonedDateTime'; Failed to convert from type [java.lang.String] to type [@org.
springframework.web.bind.annotation.RequestParam @org.springframework.format.annotation.
DateFormat @io.swagger.v3.oas.annotations.Parameter java.time.ZonedDateTime] for value [nihil]
```

Remediation

Configure your web server or application framework to include the 'Permissions-Policy' header in all responses.

Weak Security Header: HSTS

Severity:

LOW

Base CVSS Score:

4.3

CWE:

CWE_693

CAPEC Reference:

CAPEC-310

OWASP:

A02:2025 - Security Misconfiguration

Attack Vector:

API Endpoint (Network)

Technical Impact:

Unauthorized Access / Data Exposure

Endpoint: DELETE <https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/{id}>

Description

The Strict-Transport-Security (HSTS) header is present but misconfigured (missing max-age or includeSubDomains).

Evidence

HSTS value is misconfigured: max-age=631138519

Request:

```
DELETE https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/43?recurrenceDeleteOption=illo
Content-Type: application/json

{"data": "in"}
```

Response:

```
Status: 400 BAD_REQUEST
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Content-Length: 400
Content-Security-Policy: default-src 'self' https;; font-src 'self' https: data;; img-src 'self' https: data;; object-src 'none'; script-src https;; style-src 'self' https: 'unsafe-inline'
Content-Type: text/plain;charset=UTF-8
Date: Sat, 06 Jun 2026 13:23:02 GMT
Expires: 0
Pragma: no-cache
Referrer-Policy: no-referrer
Strict-Transport-Security: max-age=631138519
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
X-Content-Type-Options: nosniff
X-Correlation-Id: 9f8a5d5cefed4b19d6372966d1b9094b
X-Download-Options: noopen
X-Frame-Options: DENY
X-Permitted-Cross-Domain-Policies: none
X-Ratelimit-Burst-Capacity: 150
X-Ratelimit-Remaining: 71
X-Ratelimit-Replenish-Rate: 100
X-Ratelimit-Requested-Tokens: 1
X-Xss-Protection: 0

Method parameter 'recurrenceDeleteOption': Failed to convert value of type 'java.lang.String' to required type 'ch.hcuge.service.appointment.enums.PeriodicityUpdateOption'; Failed to convert from type [java.lang.String] to type [@org.springframework.web.bind.annotation.RequestParam @io.swagger.v3.oas.annotations.Parameter ch.hcuge.service.appointment.enums.PeriodicityUpdateOption] for value [illo]
```

Remediation

Ensure HSTS has a large max-age (e.g., 31536000) and includes 'includeSubDomains'.

Missing Security Header: Permissions-Policy

Severity:

LOW

Base CVSS Score:

4.3

CWE:

CWE_693

CAPEC Reference:

CAPEC-310

OWASP:

A02:2025 - Security Misconfiguration

Attack Vector:

API Endpoint (Network)

Technical Impact:

Unauthorized Access / Data Exposure

Endpoint: DELETE <https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/{id}>

Description

The HTTP response does not contain the 'Permissions-Policy' security header.

Evidence

Header 'Permissions-Policy' is missing from the response.

Request:

```
DELETE https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/43?recurrenceDeleteOption=illo
Content-Type: application/json

{"data": "in"}
```

Response:

```
Status: 400 BAD_REQUEST
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Content-Length: 400
Content-Security-Policy: default-src 'self' https;; font-src 'self' https: data;; img-src 'self'
https: data;; object-src 'none'; script-src https;; style-src 'self' https: 'unsafe-inline'
Content-Type: text/plain;charset=UTF-8
Date: Sat, 06 Jun 2026 13:23:02 GMT
Expires: 0
Pragma: no-cache
Referrer-Policy: no-referrer
Strict-Transport-Security: max-age=631138519
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
X-Content-Type-Options: nosniff
X-Correlation-Id: 9f8a5d5cefed4b19d6372966d1b9094b
X-Download-Options: noopen
X-Frame-Options: DENY
X-Permitted-Cross-Domain-Policies: none
X-Ratelimit-Burst-Capacity: 150
X-Ratelimit-Remaining: 71
X-Ratelimit-Replenish-Rate: 100
X-Ratelimit-Requested-Tokens: 1
X-Xss-Protection: 0

Method parameter 'recurrenceDeleteOption': Failed to convert value of type 'java.lang.String' to
required type 'ch.hcuge.service.appointment.enums.PeriodicityUpdateOption'; Failed to convert from
type [java.lang.String] to type [@org.springframework.web.bind.annotation.RequestParam @io.swagger.
v3.oas.annotations.Parameter ch.hcuge.service.appointment.enums.PeriodicityUpdateOption] for value
[illo]
```

Remediation

Configure your web server or application framework to include the 'Permissions-Policy' header in all responses.

Weak Security Header: HSTS

Severity:

LOW

Base CVSS Score:

4.3

CWE: CWE_693

CAPEC Reference: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: GET <https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments>

Description

The Strict-Transport-Security (HSTS) header is present but misconfigured (missing max-age or includeSubDomains).

Evidence

HSTS value is misconfigured: max-age=631138519

Request:

```
GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments?appointmentType=deleniti&participantActorId=dignissimos&trajectoryAdmissionState=eos&participantType=magni&start=quam&removeCancelled=true&singlePatient=true&patientAdmissionState=error&size=72&excludePending=true&end=quasi&page=69&excludeWithoutPatient=true&medicalServiceId=28&status=quis&order=ut
```

Response:

```
Status: 400 BAD_REQUEST
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Content-Length: 378
Content-Security-Policy: default-src 'self' https;; font-src 'self' https: data;; img-src 'self' https: data;; object-src 'none'; script-src https;; style-src 'self' https: 'unsafe-inline'
Content-Type: text/plain;charset=UTF-8
Date: Sat, 06 Jun 2026 13:23:02 GMT
Expires: 0
Pragma: no-cache
Referrer-Policy: no-referrer
Strict-Transport-Security: max-age=631138519
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
X-Content-Type-Options: nosniff
X-Correlation-Id: f6ff2bef9234750d1bd866866bc183ff
X-Download-Options: noopen
X-Frame-Options: DENY
X-Permitted-Cross-Domain-Policies: none
X-Ratelimit-Burst-Capacity: 150
X-Ratelimit-Remaining: 17
X-Ratelimit-Replenish-Rate: 100
X-Ratelimit-Requested-Tokens: 1
X-Xss-Protection: 0

Method parameter 'participantType': Failed to convert value of type 'java.lang.String' to required type 'ch.hcuge.service.appointment.enums.ParticipantType'; Failed to convert from type [java.lang.String] to type [@org.springframework.web.bind.annotation.RequestParam @io.swagger.v3.oas.annotations.Parameter ch.hcuge.service.appointment.enums.ParticipantType] for value [magni]
```

Remediation

Ensure HSTS has a large max-age (e.g., 31536000) and includes 'includeSubDomains'.

Missing Security Header: Permissions-Policy

Severity:

LOW

Base CVSS Score:

4.3

CWE:

CWE_693

CAPEC Reference:

CAPEC-310

OWASP:

A02:2025 - Security Misconfiguration

Attack Vector:

API Endpoint (Network)

Technical Impact:

Unauthorized Access / Data Exposure

Endpoint: GET <https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments>

Description

The HTTP response does not contain the 'Permissions-Policy' security header.

Evidence

Header 'Permissions-Policy' is missing from the response.

Request:

```
GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments?appointmentType=deleniti&participantActorId=dignissimos&trajectoryAdmissionState=eos&participantType=magni&start=quam&removeCancelled=true&singlePatient=true&patientAdmissionState=error&size=72&excludePending=true&end=quasi&page=69&excludeWithoutPatient=true&medicalServiceId=28&status=quis&order=ut
```

Response:

```
Status: 400 BAD_REQUEST
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Content-Length: 378
Content-Security-Policy: default-src 'self' https;; font-src 'self' https: data;; img-src 'self' https: data;; object-src 'none'; script-src https;; style-src 'self' https: 'unsafe-inline'
Content-Type: text/plain;charset=UTF-8
Date: Sat, 06 Jun 2026 13:23:02 GMT
Expires: 0
Pragma: no-cache
Referrer-Policy: no-referrer
Strict-Transport-Security: max-age=631138519
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
X-Content-Type-Options: nosniff
X-Correlation-Id: f6ff2bef9234750d1bd866866bc183ff
X-Download-Options: noopen
X-Frame-Options: DENY
X-Permitted-Cross-Domain-Policies: none
X-Ratelimit-Burst-Capacity: 150
X-Ratelimit-Remaining: 17
X-Ratelimit-Replenish-Rate: 100
X-Ratelimit-Requested-Tokens: 1
X-Xss-Protection: 0

Method parameter 'participantType': Failed to convert value of type 'java.lang.String' to required type 'ch.hcuge.service.appointment.enums.ParticipantType'; Failed to convert from type [java.lang.String] to type [@org.springframework.web.bind.annotation.RequestParam @io.swagger.v3.oas.annotations.Parameter ch.hcuge.service.appointment.enums.ParticipantType] for value [magni]
```

Remediation

Configure your web server or application framework to include the 'Permissions-Policy' header in all responses.

Weak Security Header: HSTS

Severity:

LOW

Base CVSS Score:

4.3

CWE: CWE_693

CAPEC Reference: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/patients/{id}/appointments

Description

The Strict-Transport-Security (HSTS) header is present but misconfigured (missing max-age or includeSubDomains).

Evidence

HSTS value is misconfigured: max-age=631138519

Request:

```
GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/patients/59/appointments?
size=44&endDate=dolorum&startDate=amet
```

Response:

```
Status: 400 BAD_REQUEST
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Content-Length: 371
Content-Security-Policy: default-src 'self' https;; font-src 'self' https: data;; img-src 'self'
https: data;; object-src 'none'; script-src https;; style-src 'self' https: 'unsafe-inline'
Content-Type: text/plain;charset=UTF-8
Date: Sat, 06 Jun 2026 13:23:02 GMT
Expires: 0
Pragma: no-cache
Referrer-Policy: no-referrer
Strict-Transport-Security: max-age=631138519
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
X-Content-Type-Options: nosniff
X-Correlation-Id: ef453d4c5a251136e7590654589970c4
X-Download-Options: noopen
X-Frame-Options: DENY
X-Permitted-Cross-Domain-Policies: none
X-Ratelimit-Burst-Capacity: 150
X-Ratelimit-Remaining: 27
X-Ratelimit-Replenish-Rate: 100
X-Ratelimit-Requested-Tokens: 1
X-Xss-Protection: 0
```

```
Method parameter 'startDate': Failed to convert value of type 'java.lang.String' to required type
'java.time.ZonedDateTime'; Failed to convert from type [java.lang.String] to type [@io.swagger.v3.
oas.annotations.Parameter @org.springframework.web.bind.annotation.RequestParam @org.
springframework.format.annotation.DateTimeFormat java.time.ZonedDateTime] for value [amet]
```

Remediation

Ensure HSTS has a large max-age (e.g., 31536000) and includes 'includeSubDomains'.

Missing Security Header: Permissions-Policy

Severity:

LOW

Base CVSS Score:

4.3

CWE:

CWE_693

CAPEC Reference:

CAPEC-310

OWASP:

A02:2025 - Security Misconfiguration

Attack Vector:

API Endpoint (Network)

Technical Impact:

Unauthorized Access / Data Exposure

Endpoint: GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/patients/{id}/appointments

Description

The HTTP response does not contain the 'Permissions-Policy' security header.

Evidence

Header 'Permissions-Policy' is missing from the response.

Request:

```
GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/patients/59/appointments?
size=44&endDate=dolorum&startDate=amet
```

Response:

```
Status: 400 BAD_REQUEST
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Content-Length: 371
Content-Security-Policy: default-src 'self' https;; font-src 'self' https: data:; img-src 'self'
https: data:; object-src 'none'; script-src https;; style-src 'self' https: 'unsafe-inline'
Content-Type: text/plain;charset=UTF-8
Date: Sat, 06 Jun 2026 13:23:02 GMT
Expires: 0
Pragma: no-cache
Referrer-Policy: no-referrer
Strict-Transport-Security: max-age=631138519
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
X-Content-Type-Options: nosniff
X-Correlation-Id: ef453d4c5a251136e7590654589970c4
X-Download-Options: noopen
X-Frame-Options: DENY
X-Permitted-Cross-Domain-Policies: none
X-Ratelimit-Burst-Capacity: 150
X-Ratelimit-Remaining: 27
X-Ratelimit-Replenish-Rate: 100
X-Ratelimit-Requested-Tokens: 1
X-Xss-Protection: 0

Method parameter 'startDate': Failed to convert value of type 'java.lang.String' to required type
'java.time.ZonedDateTime'; Failed to convert from type [java.lang.String] to type [@io.swagger.v3.
oas.annotations.Parameter @org.springframework.web.bind.annotation.RequestParam @org.
springframework.format.annotation.DateTimeFormat java.time.ZonedDateTime] for value [amet]
```

Remediation

Configure your web server or application framework to include the 'Permissions-Policy' header in all responses.

Unexpected Content-Type (Parameter Type Violation)

Severity:

LOW

Base CVSS Score:
3.7

CWE: CWE_20
CAPEC Reference: CAPEC-3
OWASP: A05:2025 - Injection
Attack Vector: API Endpoint (Network)
Technical Impact: Unauthorized Access / Data Exposure

Endpoint: DELETE <https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/{id}>

Description

The API responded with an undocumented Content-Type ('text/plain;charset=UTF-8') instead of the expected format(s): [application/json]. This often indicates an unhandled exception or bypass of the framework's standard error handler.

Evidence

Response Content-Type is: text/plain;charset=UTF-8

Request:

```
DELETE https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/invalid_string_not_number?
recurrenceDeleteOption=illo
Content-Type: application/json

{"data": "in"}
```

Response:

```
Status: 400 BAD_REQUEST
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Content-Length: 154
Content-Security-Policy: default-src 'self' https;; font-src 'self' https: data;; img-src 'self'
https: data;; object-src 'none'; script-src https;; style-src 'self' https: 'unsafe-inline'
Content-Type: text/plain;charset=UTF-8
Date: Sat, 06 Jun 2026 13:23:02 GMT
Expires: 0
Pragma: no-cache
Referrer-Policy: no-referrer
Strict-Transport-Security: max-age=631138519
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
X-Content-Type-Options: nosniff
X-Correlation-Id: 102c6b2aed3381f7109af4e033997735
X-Download-Options: noopen
X-Frame-Options: DENY
X-Permitted-Cross-Domain-Policies: none
X-Ratelimit-Burst-Capacity: 150
X-Ratelimit-Remaining: 140
X-Ratelimit-Replenish-Rate: 100
X-Ratelimit-Requested-Tokens: 1
X-Xss-Protection: 0
```

```
Method parameter 'id': Failed to convert value of type 'java.lang.String' to required type 'java.
lang.Long'; For input string: "invalid_string_not_number"
```

Remediation

Ensure that all API responses, including error messages (4xx/5xx), conform to the expected Content-Type (e. g., application/json). Check exception handlers to avoid returning raw text.

Unexpected Content-Type (Parameter Enum Violation)

Severity:

LOW

Base CVSS Score:
3.7

CWE: CWE_20
CAPEC Reference: CAPEC-3
OWASP: A05:2025 - Injection
Attack Vector: API Endpoint (Network)
Technical Impact: Unauthorized Access / Data Exposure

Endpoint: DELETE `https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/{id}`

Description

The API responded with an undocumented Content-Type ('text/plain;charset=UTF-8') instead of the expected format(s): [application/json]. This often indicates an unhandled exception or bypass of the framework's standard error handler.

Evidence

Response Content-Type is: text/plain;charset=UTF-8

Request:

```
DELETE https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/43?
recurrenceDeleteOption=ORTHRUS_INVALID_ENUM
Content-Type: application/json

{"data": "in"}
```

Response:

```
Status: 400 BAD_REQUEST
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Content-Length: 416
Content-Security-Policy: default-src 'self' https;; font-src 'self' https: data;; img-src 'self' https: data;; object-src 'none'; script-src https;; style-src 'self' https: 'unsafe-inline'
Content-Type: text/plain;charset=UTF-8
Date: Sat, 06 Jun 2026 13:23:02 GMT
Expires: 0
Pragma: no-cache
Referrer-Policy: no-referrer
Strict-Transport-Security: max-age=631138519
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
X-Content-Type-Options: nosniff
X-Correlation-Id: bd42c2adc09a6d13285b99c80138947b
X-Download-Options: noopen
X-Frame-Options: DENY
X-Permitted-Cross-Domain-Policies: none
X-Ratelimit-Burst-Capacity: 150
X-Ratelimit-Remaining: 9
X-Ratelimit-Replenish-Rate: 100
X-Ratelimit-Requested-Tokens: 1
X-Xss-Protection: 0

Method parameter 'recurrenceDeleteOption': Failed to convert value of type 'java.lang.String' to required type 'ch.hcuge.service.appointment.enums.PeriodicityUpdateOption'; Failed to convert from type [java.lang.String] to type [@org.springframework.web.bind.annotation.RequestParam @io.swagger.v3.oas.annotations.Parameter ch.hcuge.service.appointment.enums.PeriodicityUpdateOption] for value [ORTHUS_INVALID_ENUM]
```

Remediation

Ensure that all API responses, including error messages (4xx/5xx), conform to the expected Content-Type (e.g., application/json). Check exception handlers to avoid returning raw text.

Weak Security Header: HSTS

Severity:

LOW

Base CVSS Score:
4.3

CWE: CWE_693
CAPEC Reference: CAPEC-310
OWASP: A02:2025 - Security Misconfiguration
Attack Vector: API Endpoint (Network)
Technical Impact: Unauthorized Access / Data Exposure

Endpoint: POST <https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/recurrence>

Description

The Strict-Transport-Security (HSTS) header is present but misconfigured (missing max-age or includeSubDomains).

Evidence

HSTS value is misconfigured: max-age=631138519

Request:

```
POST https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/recurrence
Content-Type: application/json

{"data": "aliquid"}
```

Response:

```
Status: 400 BAD_REQUEST
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Content-Security-Policy: default-src 'self' https;; font-src 'self' https: data;; img-src 'self' https: data;; object-src 'none'; script-src https;; style-src 'self' https: 'unsafe-inline'
Content-Type: application/json
Date: Sat, 06 Jun 2026 13:23:03 GMT
Expires: 0
Pragma: no-cache
Referrer-Policy: no-referrer
Strict-Transport-Security: max-age=631138519
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
X-Content-Type-Options: nosniff
X-Correlation-Id: 32ca27d9b509455883edb2444ba23a61
X-Download-Options: noopen
X-Frame-Options: DENY
X-Permitted-Cross-Domain-Policies: none
X-Ratelimit-Burst-Capacity: 150
X-Ratelimit-Remaining: 16
X-Ratelimit-Replenish-Rate: 100
X-Ratelimit-Requested-Tokens: 1
X-Xss-Protection: 0
Transfer-Encoding: chunked

{"timestamp":"2026-06-06T13:23:03.633+00:00","status":400,"error":"Bad Request","path":"/APPOINTMENT-SERVICE/appointments/recurrence","trace-id":"32ca27d9b509455883edb2444ba23a61"}
```

Remediation

Ensure HSTS has a large max-age (e.g., 31536000) and includes 'includeSubDomains'.

Missing Security Header: Permissions-Policy

Severity:

LOW

Base CVSS Score: 4.3

CWE: CWE_693
CAPEC Reference: CAPEC-310
OWASP: A02:2025 - Security Misconfiguration
Attack Vector: API Endpoint (Network)
Technical Impact: Unauthorized Access / Data Exposure

Endpoint: POST <https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/recurrence>

Description

The HTTP response does not contain the 'Permissions-Policy' security header.

Evidence

Header 'Permissions-Policy' is missing from the response.

Request:

```
POST https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/recurrence
Content-Type: application/json

{"data": "aliquid"}
```

Response:

```
Status: 400 BAD_REQUEST
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Content-Security-Policy: default-src 'self' https;; font-src 'self' https: data:; img-src 'self' https: data:; object-src 'none'; script-src https;; style-src 'self' https: 'unsafe-inline'
Content-Type: application/json
Date: Sat, 06 Jun 2026 13:23:03 GMT
Expires: 0
Pragma: no-cache
Referrer-Policy: no-referrer
Strict-Transport-Security: max-age=631138519
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
X-Content-Type-Options: nosniff
X-Correlation-Id: 32ca27d9b509455883edb2444ba23a61
X-Download-Options: noopen
X-Frame-Options: DENY
X-Permitted-Cross-Domain-Policies: none
X-Ratelimit-Burst-Capacity: 150
X-Ratelimit-Remaining: 16
X-Ratelimit-Replenish-Rate: 100
X-Ratelimit-Requested-Tokens: 1
X-Xss-Protection: 0
Transfer-Encoding: chunked

{"timestamp":"2026-06-06T13:23:03.633+00:00","status":400,"error":"Bad Request","path":"/APPOINTMENT-SERVICE/appointments/recurrence","trace-id":"32ca27d9b509455883edb2444ba23a61"}
```

Remediation

Configure your web server or application framework to include the 'Permissions-Policy' header in all responses.

Weak Security Header: HSTS

Severity:

LOW

Base CVSS Score:

4.3

CWE: CWE_693

CAPEC Reference: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: GET <https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/v1.0/user/appointments/conflict>

Description

The Strict-Transport-Security (HSTS) header is present but misconfigured (missing max-age or includeSubDomains).

Evidence

HSTS value is misconfigured: max-age=631138519

Request:

```
GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/v1.0/user/appointments/conflict?
endDate=a&startDate=vitae
```

Response:

```
Status: 400 BAD_REQUEST
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Content-Length: 372
Content-Security-Policy: default-src 'self' https;; font-src 'self' https: data;; img-src 'self'
https: data;; object-src 'none'; script-src https;; style-src 'self' https: 'unsafe-inline'
Content-Type: text/plain;charset=UTF-8
Date: Sat, 06 Jun 2026 13:23:04 GMT
Expires: 0
Pragma: no-cache
Referrer-Policy: no-referrer
Strict-Transport-Security: max-age=631138519
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
X-Content-Type-Options: nosniff
X-Correlation-Id: c8607e0e63b1041a94baf3404b98a805
X-Download-Options: noopen
X-Frame-Options: DENY
X-Permitted-Cross-Domain-Policies: none
X-Ratelimit-Burst-Capacity: 150
X-Ratelimit-Remaining: 10
X-Ratelimit-Replenish-Rate: 100
X-Ratelimit-Requested-Tokens: 1
X-Xss-Protection: 0
```

```
Method parameter 'startDate': Failed to convert value of type 'java.lang.String' to required type
'java.time.ZonedDateTime'; Failed to convert from type [java.lang.String] to type [@org.
springframework.web.bind.annotation.RequestParam @io.swagger.v3.oas.annotations.Parameter @org.
springframework.format.annotation.DateTimeFormat java.time.ZonedDateTime] for value [vitae]
```

Remediation

Ensure HSTS has a large max-age (e.g., 31536000) and includes 'includeSubDomains'.

Missing Security Header: Permissions-Policy

Severity:

LOW

Base CVSS Score:

4.3

CWE:

CWE_693

CAPEC Reference:

CAPEC-310

OWASP:

A02:2025 - Security Misconfiguration

Attack Vector:

API Endpoint (Network)

Technical Impact:

Unauthorized Access / Data Exposure

Endpoint: GET <https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/v1.0/user/appointments/conflict>

Description

The HTTP response does not contain the 'Permissions-Policy' security header.

Evidence

Header 'Permissions-Policy' is missing from the response.

Request:

```
GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/v1.0/user/appointments/conflict?
endDate=a&startDate=vitae
```

Response:

```
Status: 400 BAD_REQUEST
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Content-Length: 372
Content-Security-Policy: default-src 'self' https;; font-src 'self' https: data:; img-src 'self'
https: data:; object-src 'none'; script-src https;; style-src 'self' https: 'unsafe-inline'
Content-Type: text/plain;charset=UTF-8
Date: Sat, 06 Jun 2026 13:23:04 GMT
Expires: 0
Pragma: no-cache
Referrer-Policy: no-referrer
Strict-Transport-Security: max-age=631138519
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
X-Content-Type-Options: nosniff
X-Correlation-Id: c8607e0e63b1041a94baf3404b98a805
X-Download-Options: noopen
X-Frame-Options: DENY
X-Permitted-Cross-Domain-Policies: none
X-Ratelimit-Burst-Capacity: 150
X-Ratelimit-Remaining: 10
X-Ratelimit-Replenish-Rate: 100
X-Ratelimit-Requested-Tokens: 1
X-Xss-Protection: 0

Method parameter 'startDate': Failed to convert value of type 'java.lang.String' to required type
'java.time.ZonedDateTime'; Failed to convert from type [java.lang.String] to type [@org.
springframework.web.bind.annotation.RequestParam @io.swagger.v3.oas.annotations.Parameter @org.
springframework.format.annotation.DateTimeFormat java.time.ZonedDateTime] for value [vitae]
```

Remediation

Configure your web server or application framework to include the 'Permissions-Policy' header in all responses.

Weak Security Header: HSTS

Severity:

LOW

Base CVSS Score:

4.3

CWE:

CWE_693

CAPEC Reference:

CAPEC-310

OWASP:

A02:2025 - Security Misconfiguration

Attack Vector:

API Endpoint (Network)

Technical Impact:

Unauthorized Access / Data Exposure

Endpoint:

PATCH https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/{appointmentId}/patients/{patientId}/statu...[TRUNCATED]

Description

The Strict-Transport-Security (HSTS) header is present but misconfigured (missing max-age or includeSubDomains).

Evidence

HSTS value is misconfigured: max-age=631138519

Request:

```
PATCH https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/11/patients/98/status-and-encounter
Content-Type: application/json

{"data": "officiis"}
```

Response:

```
Status: 400 BAD_REQUEST
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Content-Security-Policy: default-src 'self' https;; font-src 'self' https: data:; img-src 'self' https: data:; object-src 'none'; script-src https;; style-src 'self' https: 'unsafe-inline'
Content-Type: application/json
Date: Sat, 06 Jun 2026 13:23:05 GMT
Expires: 0
Pragma: no-cache
Referrer-Policy: no-referrer
Strict-Transport-Security: max-age=631138519
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
X-Content-Type-Options: nosniff
X-Correlation-Id: bdcc85c812ec55b2d8d796005ee91769
X-Download-Options: noopen
X-Frame-Options: DENY
X-Permitted-Cross-Domain-Policies: none
X-Ratelimit-Burst-Capacity: 150
X-Ratelimit-Remaining: 76
X-Ratelimit-Replenish-Rate: 100
X-Ratelimit-Requested-Tokens: 1
X-Xss-Protection: 0
Transfer-Encoding: chunked

{"timestamp":"2026-06-06T13:23:05.073+00:00","status":400,"error":"Bad Request","path":"/APPOINTMENT-SERVICE/appointments/11/patients/98/status-and-encounter","trace-id":"bdcc85c812ec55b2d8d796005ee91769"}
```

Remediation

Ensure HSTS has a large max-age (e.g., 31536000) and includes 'includeSubDomains'.

Missing Security Header: Permissions-Policy

Severity:

LOW

Base CVSS Score:

4.3

CWE:

CWE_693

CAPEC Reference:

CAPEC-310

OWASP:

A02:2025 - Security Misconfiguration

Attack Vector:

API Endpoint (Network)

Technical Impact:

Unauthorized Access / Data Exposure

Endpoint:

PATCH https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/{appointmentId}/patients/{patientId}/statu...[TRUNCATED]

Description

The HTTP response does not contain the 'Permissions-Policy' security header.

Evidence

Header 'Permissions-Policy' is missing from the response.

Request:

```
PATCH https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/11/patients/98/status-and-encounter
Content-Type: application/json

{"data": "officiis"}
```

Response:

```
Status: 400 BAD_REQUEST
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Content-Security-Policy: default-src 'self' https;; font-src 'self' https: data:; img-src 'self' https: data:; object-src 'none'; script-src https;; style-src 'self' https: 'unsafe-inline'
Content-Type: application/json
Date: Sat, 06 Jun 2026 13:23:05 GMT
Expires: 0
Pragma: no-cache
Referrer-Policy: no-referrer
Strict-Transport-Security: max-age=631138519
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
X-Content-Type-Options: nosniff
X-Correlation-Id: bdcc85c812ec55b2d8d796005ee91769
X-Download-Options: noopen
X-Frame-Options: DENY
X-Permitted-Cross-Domain-Policies: none
X-Ratelimit-Burst-Capacity: 150
X-Ratelimit-Remaining: 76
X-Ratelimit-Replenish-Rate: 100
X-Ratelimit-Requested-Tokens: 1
X-Xss-Protection: 0
Transfer-Encoding: chunked

{"timestamp":"2026-06-06T13:23:05.073+00:00","status":400,"error":"Bad Request","path":"/APPOINTMENT-SERVICE/appointments/11/patients/98/status-and-encounter","trace-id":"bdcc85c812ec55b2d8d796005ee91769"}
```

Remediation

Configure your web server or application framework to include the 'Permissions-Policy' header in all responses.

Unexpected Content-Type (Parameter Type Violation)

Severity:	Base CVSS Score:	CWE: CWE_20
LOW	3.7	CAPEC Reference: CAPEC-3
		OWASP: A05:2025 - Injection
		Attack Vector: API Endpoint (Network)
		Technical Impact: Unauthorized Access / Data Exposure
Endpoint: PATCH https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/{appointmentId}/patients/{patientId}/statu...[TRUNCATED]		

Description

The API responded with an undocumented Content-Type ('text/plain;charset=UTF-8') instead of the expected format(s): [application/json]. This often indicates an unhandled exception or bypass of the framework's standard error handler.

Evidence

Response Content-Type is: text/plain;charset=UTF-8

Request:

```
PATCH https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/11/patients
/invalid_string_not_number/status-and-encounter
Content-Type: application/json

{"data": "officiis"}
```

Response:

```
Status: 400 BAD_REQUEST
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Content-Length: 161
Content-Security-Policy: default-src 'self' https;; font-src 'self' https: data;; img-src 'self'
https: data;; object-src 'none'; script-src https;; style-src 'self' https: 'unsafe-inline'
Content-Type: text/plain;charset=UTF-8
Date: Sat, 06 Jun 2026 13:23:07 GMT
Expires: 0
Pragma: no-cache
Referrer-Policy: no-referrer
Strict-Transport-Security: max-age=631138519
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
X-Content-Type-Options: nosniff
X-Correlation-Id: 21fea3f9309f8bcf805a2d80aa3e7d2b
X-Download-Options: noopen
X-Frame-Options: DENY
X-Permitted-Cross-Domain-Policies: none
X-Ratelimit-Burst-Capacity: 150
X-Ratelimit-Remaining: 5
X-Ratelimit-Replenish-Rate: 100
X-Ratelimit-Requested-Tokens: 1
X-Xss-Protection: 0

Method parameter 'patientId': Failed to convert value of type 'java.lang.String' to required type
'java.lang.Long'; For input string: "invalid_string_not_number"
```

Remediation

Ensure that all API responses, including error messages (4xx/5xx), conform to the expected Content-Type (e. g., application/json). Check exception handlers to avoid returning raw text.

Missing Security Header: HSTS

Severity:

LOW

Base CVSS Score:

4.3

CWE:

CWE_693

CAPEC Reference:

CAPEC-310

OWASP:

A02:2025 - Security Misconfiguration

Attack Vector:

API Endpoint (Network)

Technical Impact:

Unauthorized Access / Data Exposure

Endpoint:

GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/practitioners/{practitionerId}/location

Description

The HTTP response does not contain the 'Strict-Transport-Security' security header.

Evidence

Header 'Strict-Transport-Security' is missing from the response.

Request:

```
GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/practitioners/81/location?searchDate=in
```

Response:

```
Status: 503 SERVICE_UNAVAILABLE

Error: Rate limit exceeded (429)
```

Remediation

Configure your web server or application framework to include the 'Strict-Transport-Security' header in all responses.

Missing Security Header: X-Content-Type-Options

Severity:

LOW

Base CVSS Score:

4.3

CWE:

CWE_693

CAPEC Reference:

CAPEC-310

OWASP:

A02:2025 - Security Misconfiguration

Attack Vector:

API Endpoint (Network)

Technical Impact:

Unauthorized Access / Data Exposure

Endpoint:

GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/practitioners/{practitionerId}/location

Description

The HTTP response does not contain the 'X-Content-Type-Options' security header.

Evidence

Header 'X-Content-Type-Options' is missing from the response.

Request:

```
GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/practitioners/81/location?searchDate=in
```

Response:

```
Status: 503 SERVICE_UNAVAILABLE

Error: Rate limit exceeded (429)
```

Remediation

Configure your web server or application framework to include the 'X-Content-Type-Options' header in all responses.

Missing Security Header: X-Frame-Options

Severity:

LOW

Base CVSS Score:
4.3

CWE: CWE_1021
CAPEC Reference: CAPEC-310
OWASP: A02:2025 - Security Misconfiguration
Attack Vector: API Endpoint (Network)
Technical Impact: Unauthorized Access / Data Exposure

Endpoint: GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/practitioners/{practitionerId}/location

Description

The HTTP response does not contain the 'X-Frame-Options' security header.

Evidence

Header 'X-Frame-Options' is missing from the response.

Request:

```
GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/practitioners/81/location?searchDate=in
```

Response:

```
Status: 503 SERVICE_UNAVAILABLE

Error: Rate limit exceeded (429)
```

Remediation

Configure your web server or application framework to include the 'X-Frame-Options' header in all responses.

Missing Security Header: CSP

Severity:

LOW

Base CVSS Score:

4.3

CWE: CWE_693

CAPEC Reference: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: GET <https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/practitioners/{practitionerId}/location>

Description

The HTTP response does not contain the 'Content-Security-Policy' security header.

Evidence

Header 'Content-Security-Policy' is missing from the response.

Request:

```
GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/practitioners/81/location?searchDate=in
```

Response:

```
Status: 503 SERVICE_UNAVAILABLE
```

```
Error: Rate limit exceeded (429)
```

Remediation

Configure your web server or application framework to include the 'Content-Security-Policy' header in all responses.

Missing Security Header: Permissions-Policy

Severity:

LOW

Base CVSS Score:

4.3

CWE: CWE_693

CAPEC Reference: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: GET <https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/practitioners/{practitionerId}/location>

Description

The HTTP response does not contain the 'Permissions-Policy' security header.

Evidence

Header 'Permissions-Policy' is missing from the response.

Request:

```
GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/practitioners/81/location?searchDate=in
```

Response:

```
Status: 503 SERVICE_UNAVAILABLE
```

```
Error: Rate limit exceeded (429)
```

Remediation

Configure your web server or application framework to include the 'Permissions-Policy' header in all responses.

Missing Security Header: Referrer-Policy

Severity:

LOW

Base CVSS Score:

4.3

CWE: CWE_693

CAPEC Reference: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: GET <https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/practitioners/{practitionerId}/location>

Description

The HTTP response does not contain the 'Referrer-Policy' security header.

Evidence

Header 'Referrer-Policy' is missing from the response.

Request:

```
GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/practitioners/81/location?searchDate=in
```

Response:

```
Status: 503 SERVICE_UNAVAILABLE
```

```
Error: Rate limit exceeded (429)
```

Remediation

Configure your web server or application framework to include the 'Referrer-Policy' header in all responses.

Weak Security Header: HSTS

Severity:

LOW

Base CVSS Score:

4.3

CWE: CWE_693

CAPEC Reference: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: GET <https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/activity-canvas/{modelId}/appointments>

Description

The Strict-Transport-Security (HSTS) header is present but misconfigured (missing max-age or includeSubDomains).

Evidence

HSTS value is misconfigured: max-age=631138519

Request:

```
GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/activity-canvas/54/appointments?
size=97&endDate=minus&excludePending=true&startDate=voluptate
```

Response:

```
Status: 400 BAD_REQUEST
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Content-Length: 376
Content-Security-Policy: default-src 'self' https;; font-src 'self' https: data:; img-src 'self'
https: data:; object-src 'none'; script-src https;; style-src 'self' https: 'unsafe-inline'
Content-Type: text/plain;charset=UTF-8
Date: Sat, 06 Jun 2026 13:23:33 GMT
Expires: 0
Pragma: no-cache
Referrer-Policy: no-referrer
Strict-Transport-Security: max-age=631138519
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
X-Content-Type-Options: nosniff
X-Correlation-Id: 7f4c9a0d053f16dbb2720fd31625df3e
X-Download-Options: noopen
X-Frame-Options: DENY
X-Permitted-Cross-Domain-Policies: none
X-Ratelimit-Burst-Capacity: 150
X-Ratelimit-Remaining: 48
X-Ratelimit-Replenish-Rate: 100
X-Ratelimit-Requested-Tokens: 1
X-Xss-Protection: 0

Method parameter 'startDate': Failed to convert value of type 'java.lang.String' to required type
'java.time.ZonedDateTime'; Failed to convert from type [java.lang.String] to type [@org.
springframework.web.bind.annotation.RequestParam @org.springframework.format.annotation.
DateTimeFormat @io.swagger.v3.oas.annotations.Parameter java.time.ZonedDateTime] for value
[voluptate]
```

Remediation

Ensure HSTS has a large max-age (e.g., 31536000) and includes 'includeSubDomains'.

Missing Security Header: Permissions-Policy

Severity:

LOW

Base CVSS Score:

4.3

CWE:

CWE_693

CAPEC Reference:

CAPEC-310

OWASP:

A02:2025 - Security Misconfiguration

Attack Vector:

API Endpoint (Network)

Technical Impact:

Unauthorized Access / Data Exposure

Endpoint:

GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/activity-canvas/{modelId}/appointments

Description

The HTTP response does not contain the 'Permissions-Policy' security header.

Evidence

Header 'Permissions-Policy' is missing from the response.

Request:

```
GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/activity-canvas/54/appointments?
size=97&endDate=minus&excludePending=true&startDate=voluptate
```

Response:

```
Status: 400 BAD_REQUEST
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Content-Length: 376
Content-Security-Policy: default-src 'self' https;; font-src 'self' https: data:; img-src 'self'
https: data:; object-src 'none'; script-src https;; style-src 'self' https: 'unsafe-inline'
Content-Type: text/plain;charset=UTF-8
Date: Sat, 06 Jun 2026 13:23:33 GMT
Expires: 0
Pragma: no-cache
Referrer-Policy: no-referrer
Strict-Transport-Security: max-age=631138519
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
X-Content-Type-Options: nosniff
X-Correlation-Id: 7f4c9a0d053f16dbb2720fd31625df3e
X-Download-Options: noopen
X-Frame-Options: DENY
X-Permitted-Cross-Domain-Policies: none
X-Ratelimit-Burst-Capacity: 150
X-Ratelimit-Remaining: 48
X-Ratelimit-Replenish-Rate: 100
X-Ratelimit-Requested-Tokens: 1
X-Xss-Protection: 0

Method parameter 'startDate': Failed to convert value of type 'java.lang.String' to required type
'java.time.ZonedDateTime'; Failed to convert from type [java.lang.String] to type [@org.
springframework.web.bind.annotation.RequestParam @org.springframework.format.annotation.
DateTimeFormat @io.swagger.v3.oas.annotations.Parameter java.time.ZonedDateTime] for value
[voluptate]
```

Remediation

Configure your web server or application framework to include the 'Permissions-Policy' header in all responses.

Weak Security Header: HSTS

Severity:

LOW

Base CVSS Score:

4.3

CWE:

CWE_693

CAPEC Reference:

CAPEC-310

OWASP:

A02:2025 - Security Misconfiguration

Attack Vector:

API Endpoint (Network)

Technical Impact:

Unauthorized Access / Data Exposure

Endpoint: GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/{participantType}

Description

The Strict-Transport-Security (HSTS) header is present but misconfigured (missing max-age or includeSubDomains).

Evidence

HSTS value is misconfigured: max-age=631138519

Request:

```
GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/voluptatum?singlePatient=true&appointmentType=null&size=92&start=similique&excludePending=true&removeCancelled=true&end=aut&page=6&excludeWithoutPatient=true&medicalServiceId=32&participantActorIds=temporibus&status=minima
```

Response:

```
Status: 400 BAD_REQUEST
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Content-Length: 383
Content-Security-Policy: default-src 'self' https;; font-src 'self' https: data;; img-src 'self' https: data;; object-src 'none'; script-src https;; style-src 'self' https: 'unsafe-inline'
Content-Type: text/plain;charset=UTF-8
Date: Sat, 06 Jun 2026 13:23:33 GMT
Expires: 0
Pragma: no-cache
Referrer-Policy: no-referrer
Strict-Transport-Security: max-age=631138519
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
X-Content-Type-Options: nosniff
X-Correlation-Id: 9a4072ac471210c179f7295f630eba14
X-Download-Options: noopen
X-Frame-Options: DENY
X-Permitted-Cross-Domain-Policies: none
X-Ratelimit-Burst-Capacity: 150
X-Ratelimit-Remaining: 33
X-Ratelimit-Replenish-Rate: 100
X-Ratelimit-Requested-Tokens: 1
X-Xss-Protection: 0

Method parameter 'participantType': Failed to convert value of type 'java.lang.String' to required type 'ch.hcuge.service.appointment.enums.ParticipantType'; Failed to convert from type [java.lang.String] to type [@org.springframework.web.bind.annotation.PathVariable @io.swagger.v3.oas.annotations.Parameter ch.hcuge.service.appointment.enums.ParticipantType] for value [voluptatum]
```

Remediation

Ensure HSTS has a large max-age (e.g., 31536000) and includes 'includeSubDomains'.

Missing Security Header: Permissions-Policy

Severity:

LOW

Base CVSS Score:

4.3

CWE:

CWE_693

CAPEC Reference:

CAPEC-310

OWASP:

A02:2025 - Security Misconfiguration

Attack Vector:

API Endpoint (Network)

Technical Impact:

Unauthorized Access / Data Exposure

Endpoint: GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/{participantType}

Description

The HTTP response does not contain the 'Permissions-Policy' security header.

Evidence

Header 'Permissions-Policy' is missing from the response.

Request:

```
GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/voluptatum?singlePatient=true&appointm
entType=null&size=92&start=similique&excludePending=true&removeCancelled=true&end=aut&page=6&exclud
eWithoutPatient=true&medicalServiceId=32&participantActorIds=temporibus&status=minima
```

Response:

```
Status: 400 BAD_REQUEST
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Content-Length: 383
Content-Security-Policy: default-src 'self' https;; font-src 'self' https: data;; img-src 'self'
https: data;; object-src 'none'; script-src https;; style-src 'self' https: 'unsafe-inline'
Content-Type: text/plain;charset=UTF-8
Date: Sat, 06 Jun 2026 13:23:33 GMT
Expires: 0
Pragma: no-cache
Referrer-Policy: no-referrer
Strict-Transport-Security: max-age=631138519
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
X-Content-Type-Options: nosniff
X-Correlation-Id: 9a4072ac471210c179f7295f630eba14
X-Download-Options: noopen
X-Frame-Options: DENY
X-Permitted-Cross-Domain-Policies: none
X-Ratelimit-Burst-Capacity: 150
X-Ratelimit-Remaining: 33
X-Ratelimit-Replenish-Rate: 100
X-Ratelimit-Requested-Tokens: 1
X-Xss-Protection: 0

Method parameter 'participantType': Failed to convert value of type 'java.lang.String' to required
type 'ch.hcuge.service.appointment.enums.ParticipantType'; Failed to convert from type [java.lang.
String] to type [@org.springframework.web.bind.annotation.PathVariable @io.swagger.v3.oas.
annotations.Parameter ch.hcuge.service.appointment.enums.ParticipantType] for value [voluptatum]
```

Remediation

Configure your web server or application framework to include the 'Permissions-Policy' header in all responses.

Weak Security Header: HSTS

Severity:

LOW

Base CVSS Score:

4.3

CWE: CWE_693

CAPEC Reference: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: GET <https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/{id}/history>

Description

The Strict-Transport-Security (HSTS) header is present but misconfigured (missing max-age or includeSubDomains).

Evidence

HSTS value is misconfigured: max-age=631138519

Request:

```
GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/67/history?operationTypes=nostrum
```

Response:

```
Status: 400 BAD_REQUEST
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Content-Length: 339
Content-Security-Policy: default-src 'self' https;; font-src 'self' https: data:; img-src 'self' https: data:; object-src 'none'; script-src https;; style-src 'self' https: 'unsafe-inline'
Content-Type: text/plain;charset=UTF-8
Date: Sat, 06 Jun 2026 13:23:34 GMT
Expires: 0
Pragma: no-cache
Referrer-Policy: no-referrer
Strict-Transport-Security: max-age=631138519
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
X-Content-Type-Options: nosniff
X-Correlation-Id: 100469213f98c9de32a713b4baada405
X-Download-Options: noopen
X-Frame-Options: DENY
X-Permitted-Cross-Domain-Policies: none
X-Ratelimit-Burst-Capacity: 150
X-Ratelimit-Remaining: 92
X-Ratelimit-Replenish-Rate: 100
X-Ratelimit-Requested-Tokens: 1
X-Xss-Protection: 0

Method parameter 'operationTypes': Failed to convert value of type 'java.lang.String' to required type 'java.util.List'; Failed to convert from type [java.lang.String] to type [@org.springframework.web.bind.annotation.RequestParam @io.swagger.v3.oas.annotations.Parameter ch.hcuge.service.appointment.enums.HistoryType] for value [nostrum]
```

Remediation

Ensure HSTS has a large max-age (e.g., 31536000) and includes 'includeSubDomains'.

Missing Security Header: Permissions-Policy

Severity:

LOW

Base CVSS Score: 4.3

CWE: CWE_693
CAPEC Reference: CAPEC-310
OWASP: A02:2025 - Security Misconfiguration
Attack Vector: API Endpoint (Network)
Technical Impact: Unauthorized Access / Data Exposure

Endpoint: GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/{id}/history

Description

The HTTP response does not contain the 'Permissions-Policy' security header.

Evidence

Header 'Permissions-Policy' is missing from the response.

Request:

```
GET https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/67/history?operationTypes=nostrum
```

Response:

```
Status: 400 BAD_REQUEST
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Content-Length: 339
Content-Security-Policy: default-src 'self' https;; font-src 'self' https: data:; img-src 'self' https: data:; object-src 'none'; script-src https;; style-src 'self' https: 'unsafe-inline'
Content-Type: text/plain;charset=UTF-8
Date: Sat, 06 Jun 2026 13:23:34 GMT
Expires: 0
Pragma: no-cache
Referrer-Policy: no-referrer
Strict-Transport-Security: max-age=631138519
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
X-Content-Type-Options: nosniff
X-Correlation-Id: 100469213f98c9de32a713b4baada405
X-Download-Options: noopen
X-Frame-Options: DENY
X-Permitted-Cross-Domain-Policies: none
X-Ratelimit-Burst-Capacity: 150
X-Ratelimit-Remaining: 92
X-Ratelimit-Replenish-Rate: 100
X-Ratelimit-Requested-Tokens: 1
X-Xss-Protection: 0

Method parameter 'operationTypes': Failed to convert value of type 'java.lang.String' to required type 'java.util.List'; Failed to convert from type [java.lang.String] to type [@org.springframework.web.bind.annotation.RequestParam @io.swagger.v3.oas.annotations.Parameter ch.hcuge.service.appointment.enums.HistoryType] for value [nostrum]
```

Remediation

Configure your web server or application framework to include the 'Permissions-Policy' header in all responses.

Weak Security Header: CSP

Severity:

INFO

Base CVSS Score:

0.0

CWE: CWE_693

CAPEC Reference: CAPEC-63

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: POST <https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/recurrence>

Description

The Content-Security-Policy header contains 'unsafe-inline' for 'style-src'. Since this API response is JSON (application/json), the risk of CSS injection is minimal. However, best practices still recommend removing it.

Evidence

CSP value contains unsafe directives: default-src 'self' https;; font-src 'self' https: data;; img-src 'self' https: data;; object-src 'none'; script-src https;; style-src 'self' https: 'unsafe-inline'

Request:

```
POST https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/recurrence
Content-Type: application/json

{"data": "aliquid"}
```

Response:

```
Status: 400 BAD_REQUEST
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Content-Security-Policy: default-src 'self' https;; font-src 'self' https: data;; img-src 'self' https: data;; object-src 'none'; script-src https;; style-src 'self' https: 'unsafe-inline'
Content-Type: application/json
Date: Sat, 06 Jun 2026 13:23:03 GMT
Expires: 0
Pragma: no-cache
Referrer-Policy: no-referrer
Strict-Transport-Security: max-age=631138519
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
X-Content-Type-Options: nosniff
X-Correlation-Id: 32ca27d9b509455883edb2444ba23a61
X-Download-Options: noopen
X-Frame-Options: DENY
X-Permitted-Cross-Domain-Policies: none
X-Ratelimit-Burst-Capacity: 150
X-Ratelimit-Remaining: 16
X-Ratelimit-Replenish-Rate: 100
X-Ratelimit-Requested-Tokens: 1
X-Xss-Protection: 0
Transfer-Encoding: chunked

{"timestamp":"2026-06-06T13:23:03.633+00:00","status":400,"error":"Bad Request","path":"/APPOINTMENT-SERVICE/appointments/recurrence","trace-id":"32ca27d9b509455883edb2444ba23a61"}
```

Remediation

Remove 'unsafe-inline' and 'unsafe-eval' from your CSP and use nonces or hashes instead.

Weak Security Header: CSP

Severity:

INFO

Base CVSS Score:

0.0

CWE:

CWE_693

CAPEC Reference:

CAPEC-63

OWASP:

A02:2025 - Security Misconfiguration

Attack Vector:

API Endpoint (Network)

Technical Impact:

Unauthorized Access / Data Exposure

Endpoint:

PATCH https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/{appointmentId}/patients/{patientId}/statu...[TRUNCATED]

Description

The Content-Security-Policy header contains 'unsafe-inline' for 'style-src'. Since this API response is JSON (application/json), the risk of CSS injection is minimal. However, best practices still recommend removing it.

Evidence

CSP value contains unsafe directives: default-src 'self' https;; font-src 'self' https: data;; img-src 'self' https: data;; object-src 'none'; script-src https;; style-src 'self' https: 'unsafe-inline'

Request:

```
PATCH https://api-dev.hcuge.ch/APPOINTMENT-SERVICE/appointments/11/patients/98/status-and-encounter
Content-Type: application/json

{"data": "officiis"}
```

Response:

```
Status: 400 BAD_REQUEST
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Content-Security-Policy: default-src 'self' https;; font-src 'self' https: data;; img-src 'self' https: data;; object-src 'none'; script-src https;; style-src 'self' https: 'unsafe-inline'
Content-Type: application/json
Date: Sat, 06 Jun 2026 13:23:05 GMT
Expires: 0
Pragma: no-cache
Referrer-Policy: no-referrer
Strict-Transport-Security: max-age=631138519
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
X-Content-Type-Options: nosniff
X-Correlation-Id: bdcc85c812ec55b2d8d796005ee91769
X-Download-Options: noopen
X-Frame-Options: DENY
X-Permitted-Cross-Domain-Policies: none
X-Ratelimit-Burst-Capacity: 150
X-Ratelimit-Remaining: 76
X-Ratelimit-Replenish-Rate: 100
X-Ratelimit-Requested-Tokens: 1
X-Xss-Protection: 0
Transfer-Encoding: chunked

{"timestamp":"2026-06-06T13:23:05.073+00:00","status":400,"error":"Bad Request","path":"/APPOINTMENT-SERVICE/appointments/11/patients/98/status-and-encounter","trace-id":"bdcc85c812ec55b2d8d796005ee91769"}
```

Remediation

Remove 'unsafe-inline' and 'unsafe-eval' from your CSP and use nonces or hashes instead.

